

Chapter 7: Ethics and Legal Issues

Privacy, Consent, Jurisdiction, and Professional Responsibility

Companion Workbook to the Instructional Video

An Important Note Before You Begin

This chapter is educational material, not legal advice. It describes legal concepts in general terms so that you can recognize when a question is a legal question. It cannot tell you what the law requires of you, because that depends on your jurisdiction, your sector, your role, the facts of your situation, and law that changes continuously.

Three things follow from that, and they are practical rather than decorative:

Recognize, then escalate. The professional skill this chapter teaches is spotting the issue and knowing that it needs qualified advice, not deciding it yourself. An investigator who says "this raises a data protection question and I have stopped pending advice" is doing the job correctly. One who reads a chapter and concludes they know the answer is not.

Jurisdictions differ, substantially. A practice that is routine in one country is unlawful in another. Where this chapter names a specific statute or regime, it is an illustration of a concept, not a statement of what applies to you.

Law changes. Data protection, computer misuse, scraping, and disclosure law have all moved significantly in recent years and continue to. Anything you learn here should be checked against current sources before you rely on it.

How to Use This Workbook

This is the written companion to the instructional video on ethics and legal issues. It works as a follow-along guide, a standalone textbook chapter, and a practice manual.

Where this chapter sits in the series. Chapters 1 through 3 covered intelligence, OSINT, and sources. Chapter 4 covered the collection process, Chapter 5 the reasoning, and Chapter 6 the planning and evidence discipline. **This chapter covers the constraints that sit over all of it.**

Every previous chapter has carried rules forward. This is the chapter that explains where they came from. Rule 1 (no private individuals) exists because of the material in Sections 1.2 and 1.10. Rule 2 (publicly available means genuinely public) exists because of Sections 1.3 and 1.9. Rule 5 (automation is constrained) exists because of Section 1.9. You have been operating under this chapter's conclusions for six chapters; now you get the reasoning.

Time estimate:

Component	Estimated time
Video	60 to 75 minutes
Reading material	5 to 6 hours
Knowledge assessment	1 hour
Critical thinking exercises	2 to 2.5 hours
Labs 1 through 5	11 to 16 hours
Capstone assignment	6 to 9 hours
Total	26 to 35 hours

Materials: a word processor and a spreadsheet application. No collection is required for any exercise in this chapter; every lab uses provided fictional material, deliberately, because a chapter about restraint should not ask you to go collecting.

The Rules Still Apply

Rule 1: No private individuals. Rule 2: Publicly available means genuinely public. Rule 3: Document as you go. Rule 4: No dark web access. Rule 5: Automation is constrained. Rule 6: A relationship is a claim, and every claim needs a basis. Rule 7: If it is not written down, it did not happen.

This chapter adds the rule that governs the other seven:

Rule 8: Lawful is the floor, not the ceiling. Where law and ethics diverge, the stricter one governs your conduct. A great deal of investigative activity is perfectly lawful and should not be done. The law sets a minimum that societies enforce; professional ethics set a standard that practitioners hold themselves to, and the gap between them is where most of the real decisions in this field live. Section 1.1.3 develops this, and every case study in Part 3 turns on it.

Learning Objectives

Knowledge objectives (you can explain it):

1. Distinguish legal and ethical questions, and explain why an activity can be lawful and unacceptable.
2. Explain what privacy protects, and describe the concepts of reasonable expectation of privacy, contextual integrity, and the mosaic effect.
3. Distinguish personal data, personally identifiable information, sensitive or special category data,

and non-personal data.

4. Explain the core principles common to modern data protection regimes.
5. Explain why "publicly available" answers a question about the source and not about the collector's authority.
6. Distinguish explicit, implied, informed, and inferred consent, and explain when consent is and is not the relevant question.
7. Explain the basics of copyright, fair use or fair dealing, the public domain, and open licensing as they affect investigative work.
8. Explain data retention obligations, minimization, and secure disposal, and why holding data is a liability as well as an asset.
9. Explain how jurisdiction arises, and describe the ways an investigation can touch several jurisdictions at once.
10. Explain coordinated vulnerability disclosure, the roles involved, and why timelines exist.
11. Describe the categories of legal limitation that constrain investigative work.
12. Describe at least two ethical decision frameworks and apply one.

Application objectives (you can do it):

1. Classify sample information as public, private, sensitive, or protected, and justify each classification.
2. Determine whether a proposed collection raises a privacy, consent, copyright, or jurisdictional issue, and identify which.
3. Apply a structured ethical decision framework to a real dilemma and document the reasoning.
4. Build a data retention and disposal schedule for an investigation.
5. Produce a responsible disclosure plan and draft a professional disclosure communication.
6. Revise an investigation plan to remove or mitigate identified legal and ethical risks.

Analysis objectives (you can judge it):

1. Evaluate an investigative practice against both legal and ethical standards and identify where they diverge.
 2. Assess whether a proposed collection is proportionate to its purpose.
 3. Recognize when a question requires qualified legal advice and articulate what you would ask.
 4. Judge whether a disclosure process was handled responsibly by all parties.
-

Part 1: Reading Material

1.1 Introduction to Ethics and Legal Issues

1.1.1 Why This Chapter Exists

Investigative capability is asymmetric. The investigator chooses the subject; the subject does not choose to be investigated. The investigator assembles a picture; the subject frequently never knows the picture exists. That asymmetry is the reason this field has ethics at all, and it is why "I only used public sources" is a description of method rather than a justification.

Three practical consequences follow.

Capability is not authorization. That you can find something says nothing about whether you may, should, or should record it.

Harm is asymmetric too. An error in an investigation costs the investigator time and costs the subject their reputation, their employment, or their safety. The person bearing the risk of your mistake is usually not you.

Nobody is watching. In most OSINT work there is no gatekeeper approving each collection. The decision is made by one person, alone, under time pressure, with an interesting thread in front of them. That person is you, and the frameworks in this chapter exist because judgment in the moment is unreliable without them.

1.1.2 The Two Questions, and They Are Different

Every investigative decision raises two separate questions that beginners collapse into one.

	The legal question	The ethical question
Asks	Is this permitted?	Is this right?
Source of the answer	Statute, regulation, case law, contract, terms of service	Professional standards, codes of conduct, moral reasoning, the profession's expectations
Enforced by	Courts, regulators, prosecutors, contractual counterparties	Professional bodies, employers, editors, colleagues, and your own standards
Consequence of getting it wrong	Liability, prosecution, sanction, inadmissibility, contract termination	Harm to a person, reputational damage, loss of trust, and sometimes nothing external at all
Varies by	Jurisdiction, sector, role	Profession, context, and the specific relationship to the subject
Determinable in advance	Often, with advice	Frequently requires judgment about a specific situation
Who decides	Ultimately a court or regulator	You, in the moment, usually

	The legal question	The ethical question
		with no review

Four combinations exist and all four occur constantly:

	ETHICAL	UNETHICAL
LEGAL	A Proceed. This is most of professional work.	B The largest and most dangerous quadrant. Lawful and you should not do it.
ILLEGAL	C Rare, real, and not your call alone. Escalate to counsel.	D Do not. There is no dilemma here.

Quadrant B is where this chapter lives. Compiling a complete profile of a private individual from public posts is lawful in many places and is surveillance. Buying a data broker file on someone is lawful in many places and is not something a professional does casually. Publishing an unverified identification is lawful right up until it is defamatory and is unconscionable regardless. Rule 8 exists for quadrant B.

Quadrant C deserves a word. Occasionally an ethical obligation appears to point at something unlawful: a journalist who has obtained material they were not authorized to receive, an investigator who has found evidence of imminent harm. These situations are real, they are rare, and they are **not decisions for an individual investigator to make alone**. The correct action is always to stop, preserve, and escalate to counsel and to your organization. Any chapter that encouraged you to resolve quadrant C by yourself would be doing you harm.

1.1.3 Lawful Is the Floor

The single most important idea in this chapter, stated plainly.

The law is the minimum standard a society is prepared to enforce against everyone, including people acting in bad faith. It is written broadly, it lags technology by years, and it is silent on most of what an investigator actually does in a day.

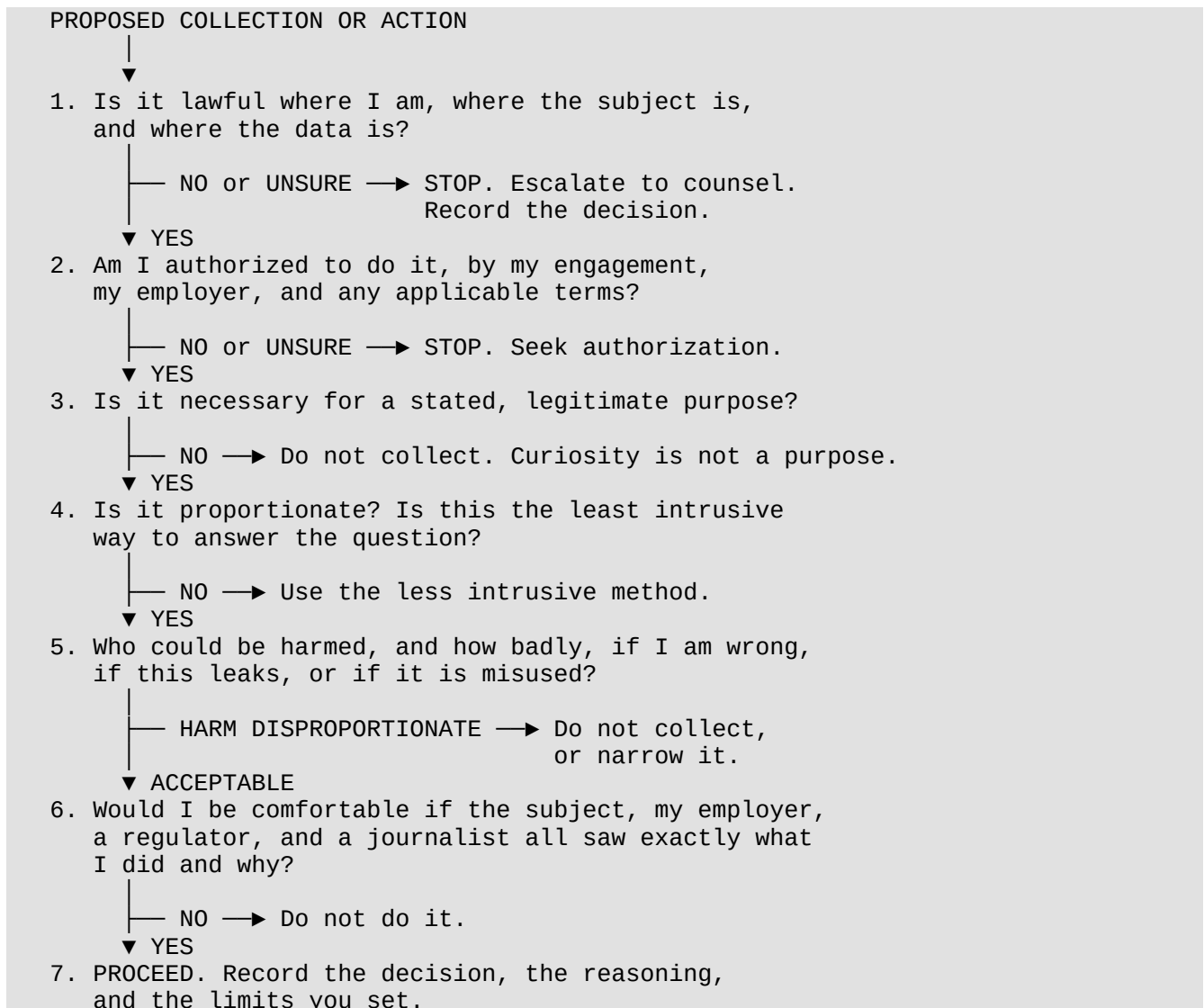
Professional ethics are the standard practitioners hold themselves to because the work is powerful and the subjects are vulnerable to it. They are stricter than the law by design.

	Law	Professional ethics
Standard	Minimum enforceable	What a competent professional does
Coverage	Narrow; most conduct is	Broad; covers judgment calls

	Law	Professional ethics
	unaddressed	
Update speed	Years	Continuously, through practice and codes
Applies to	Everyone	Those who claim the professional standard
Failure	Sanctioned externally	Frequently invisible, which is why it matters

The practical formulation: every proposed action passes two gates. If it fails the legal gate, stop and escalate. If it passes the legal gate but fails the ethical gate, do not do it. Only actions passing both proceed.

1.1.4 The Decision Flow



Step 7 is not optional. A decision to proceed that is not recorded is indistinguishable, later, from not having thought about it.

1.1.5 Where the Pressure Comes From

Knowing the framework is easy. Applying it under pressure is the skill, and the pressures are predictable:

Pressure	How it sounds	The counter
Deadline	"We need this by Friday"	The deadline is a constraint on scope, not on standards
Client expectation	"Our last investigator got us this"	Decline, explain, and offer the lawful alternative
Curiosity	"This is fascinating, let me just check one more thing"	Curiosity is not a purpose. Return to the requirement
Sunk effort	"We have come this far"	Prior effort does not authorize the next step
Moral certainty	"This person is clearly guilty"	Certainty is exactly when the framework matters most
Availability	"It is right there, anyone could find it"	Availability is not authorization
Team norms	"Everyone does this"	The norm may be the problem
Ambiguity	"Nobody has actually said we cannot"	Silence is not permission; escalate

Moral certainty deserves the most attention. The investigations that produce ethical catastrophes are almost never the ones where the investigator thought they might be doing something wrong. They are the ones where the investigator was sure they were right.

1.2 Privacy

1.2.1 What Privacy Protects

Privacy is not secrecy. Most of what privacy protects is not secret at all; it is information a person has shared in a particular context and expects to stay in that context.

Three concepts do most of the analytic work.

Reasonable expectation of privacy. A legal concept in several jurisdictions, and a useful ethical one everywhere: would a reasonable person expect this to be observed, recorded, or compiled? Someone walking down a public street expects to be seen. They do not expect their movements to be recorded, compiled across months, and matched to their identity.

Contextual integrity. Information flows have norms attached to their context. A person shares their address with a delivery company, their health information with a clinician, and their political views with friends. Each flow is appropriate in context. Moving information from its original context into another, without a norm supporting the move, is a privacy violation even if no rule was broken and nothing was secret.

The mosaic effect. Introduced in Chapter 2 and central here. Individually innocuous public facts, assembled, produce something the subject never made public and would not have consented to. Employer plus gym schedule plus vehicle plus neighbourhood plus children's school is not five public facts; it is a targeting package. **The aggregate is a new thing, and you created it.**

1.2.2 Categories of Data

Category	Definition	Examples	Handling implication
Personal data	Any information relating to an identified or identifiable person. The broadest category in most modern regimes	Name, address, email, IP address in many contexts, device identifiers, employee ID	Processing is regulated; needs a purpose and often a lawful basis
Personally identifiable information (PII)	A narrower, largely US-derived concept: data that identifies a specific individual, directly or in combination	Government ID number, full name plus date of birth, account numbers	Regulated by sector-specific rules; breach notification obligations attach
Sensitive or special category data	Data whose misuse creates heightened risk	Health, biometrics, genetics, race or ethnicity, religious or philosophical belief, political opinion, trade union membership, sexual orientation, criminal history in some regimes	Frequently prohibited to process without a specific and narrow basis. Treat as off limits unless you have advice
Non-personal data	Data not relating to an identifiable person	Aggregate statistics, weather, corporate financials, geological data	Generally unregulated as personal data; other rules may still apply
Pseudonymized data	Personal data with identifiers replaced, but re-identifiable with additional information	An analysis keyed to "Subject A" with a separate key	Still personal data in most regimes; the protection is real but partial
Anonymized data	Personal data irreversibly de-identified	Aggregate counts with small cells suppressed	Generally outside data protection regimes, if genuinely irreversible

Two cautions that matter in practice.

Re-identification is easier than people assume. Small numbers of quasi-identifiers (approximate location, approximate age, an occupation, a date) can uniquely identify individuals in a population. "Anonymized" is a technical claim that must be justified, not a label applied by hoping.

PII and personal data are not synonyms. Personal data is broader. A dataset containing no PII in the narrow sense may still be personal data and still be regulated.

1.2.3 Principles Common to Modern Data Protection

Regimes differ in detail. These principles recur across most of them, and they are worth knowing as concepts because they translate directly into investigative practice.

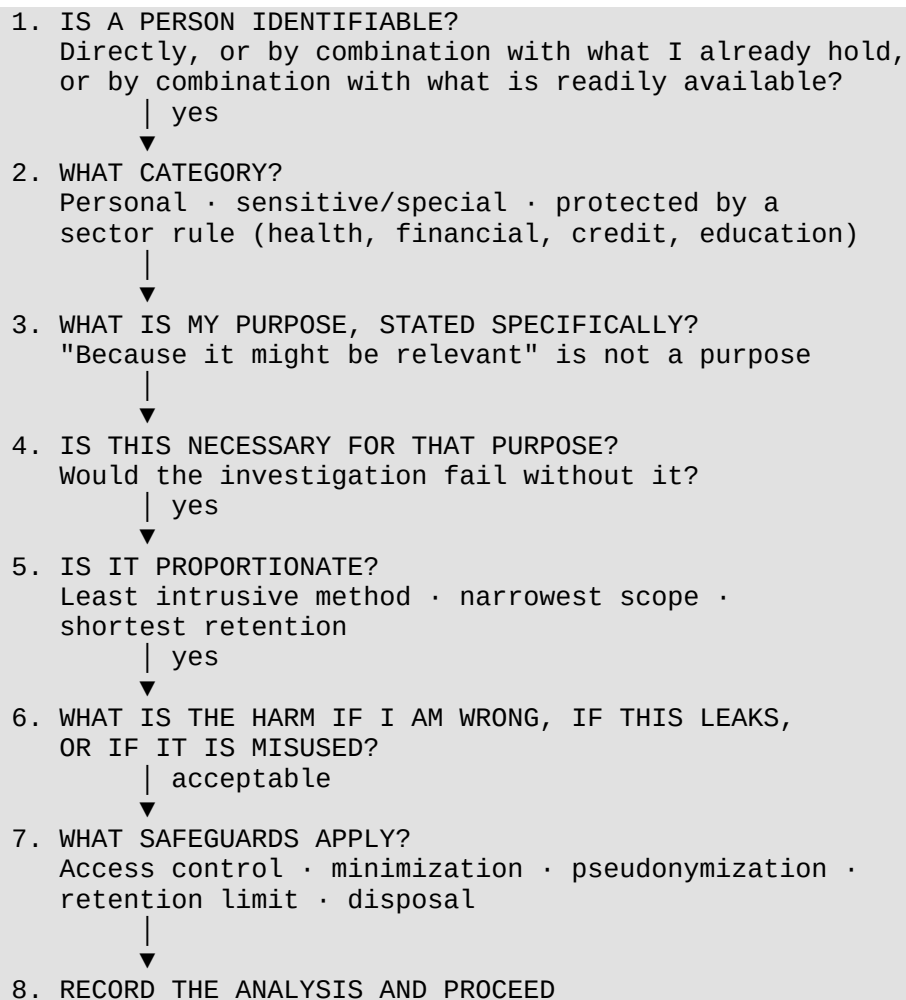
Principle	What it means	What it means for an investigator
Lawfulness, fairness, transparency	There must be a legal basis, the processing must be fair, and people should generally know it happens	You need a reason that survives being stated out loud
Purpose limitation	Data collected for one purpose may not be freely repurposed	Evidence collected for investigation A is not available for investigation B without analysis
Data minimization	Collect only what is necessary for the purpose	The strongest single constraint on OSINT practice. Do not collect because you can
Accuracy	Data should be accurate and kept up to date	An unverified attribution about a person is a data protection problem as well as an analytic one
Storage limitation	Keep it only as long as necessary	Retention schedules, Section 1.6
Integrity and confidentiality	Protect it	Chapter 6's custody and access controls are a data protection obligation, not only good practice
Accountability	Be able to demonstrate compliance	Chapter 6's documentation, again

Lawful bases, in regimes that require one, typically include consent, contract, legal obligation, vital interests, public task, and legitimate interests. Most private investigative work relies on **legitimate interests**, which is not a free pass: it requires a documented balancing of the investigator's interest against the individual's rights, and it fails where the individual's rights outweigh the interest. Where you rely on it, write the balancing down.

Individual rights in many regimes include access, rectification, erasure, restriction, objection, and portability. Investigations frequently qualify for narrow exemptions from some of these, and the existence and scope of any exemption is precisely the sort of question that requires advice.

1.2.4 Privacy Analysis for an Investigator

A workable sequence for any proposed collection touching a person:



Steps 4 and 5 are the ones that stop most bad collection, and they are the ones investigators skip, because "it might be relevant" feels like diligence.

1.2.5 Privacy Harms Are Concrete

Abstract privacy talk makes it easy to discount. The harms are specific:

Harm	Mechanism
Physical safety	Location, routine, and vehicle information enable stalking and violence
Employment	An unverified allegation, once findable, follows a person indefinitely

Harm	Mechanism
Financial	Identity theft and fraud from assembled identifiers
Reputational	Association with an investigation is damaging regardless of outcome
Chilling	People who believe they are watched change lawful behavior: what they read, who they associate with, what they say
Discrimination	Sensitive attributes, once inferred, are used in decisions they should never touch
Dignitary	The experience of being profiled, which is a harm even where nothing else follows

The chilling harm is the one investigators most often dismiss and the one that most affects populations rather than individuals. It is why collection about lawful political, religious, and associational activity is restricted in most democratic systems, and why an investigator should be uncomfortable collecting it even where no rule forbids it.

1.2.6 Privacy of Third Parties

The subject of an investigation is not the only person whose data you will encounter. Family members, colleagues, complainants, bystanders in a photograph, and unrelated people in a dataset all appear.

The rule this course has applied since Chapter 2: individuals appear in your work only in a capacity relevant to a stated requirement, never as subjects in themselves, never as family members or associates of a subject, and never if they are minors. Third parties encountered incidentally are recorded as encountered and excluded, and that exclusion is itself documented.

Minors are categorical. Do not collect about minors. Not as subjects, not as family members, not as bystanders, not "just to confirm the family structure." If a legitimate investigation genuinely requires information about a minor, it is a matter for counsel and for the appropriate authorities, not for an open source investigator working alone.

1.3 Public Information

1.3.1 The Sentence That Governs This Section

"It is public" answers a question about the source. It does not answer the question about your authority to collect, retain, or use it.

This was stated in Chapter 3 and it is worth the full treatment here, because it is the single most common error in open source practice and it is made in good faith by intelligent people.

1.3.2 Four Distinct Questions

When someone says information is "public," they may mean any of four things, and the differences matter.

Question	What it asks	Answer does not imply
Accessibility	Can I reach it without defeating a control?	That I may use it
Authorization	Am I permitted to collect it, given who I am?	That it is ethical
Lawfulness of use	May I use it for my purpose?	That collection was lawful
Propriety	Should I, given the harm and the purpose?	Anything about legality

An investigator who has answered only the first has answered the easiest question and none of the hard ones.

1.3.3 Degrees of Public

"Public" is not binary. A useful ladder, from most to least public:

Degree	Description	Examples	Collection considerations
Published for the public	Deliberately released to the world	Press releases, published filings, court opinions, official statistics	Least constrained; copyright still applies
Public by legal requirement	Made public because law requires disclosure	Corporate registries, property records, permits, legal notices, campaign finance	Public by design; purpose limitations may still apply to reuse
Publicly accessible by default	Available because a platform's default settings expose it	Public social posts, forum posts, profile pages	Accessible, and frequently not intended as "publication" by the person
Public but practically obscure	Technically available, hard to find, and never expected to be aggregated	Old records in a physical archive, results deep in a database	Practical obscurity is a real value; destroying it is a decision
Available due to error	Exposed by misconfiguration or mistake	Files on an unsecured server, a mis-set permission, an unlisted URL that was meant to be private	Not public. Availability by error is not publication
Available through	Reachable only by	Anything behind a	Not public. Outside

Degree	Description	Examples	Collection considerations
circumvention	defeating a control	login, a paywall bypass, credential use	OSINT entirely

The middle rows are where judgment lives. A person posting to a public profile has made something accessible; whether they have "published" it in any meaningful sense is a different question, and contextual integrity says the answer is often no.

Practical obscurity deserves its own paragraph. Information that is technically public but difficult to find has, in effect, been protected by friction. Aggregation removes the friction. A criminal record from twenty years ago in a paper courthouse index and the same record surfaced instantly by a search are legally identical and practically different, and the difference is the whole of that person's ability to move on. Recognizing that you are the one removing the friction is part of the job.

1.3.4 Public Does Not Mean Unowned

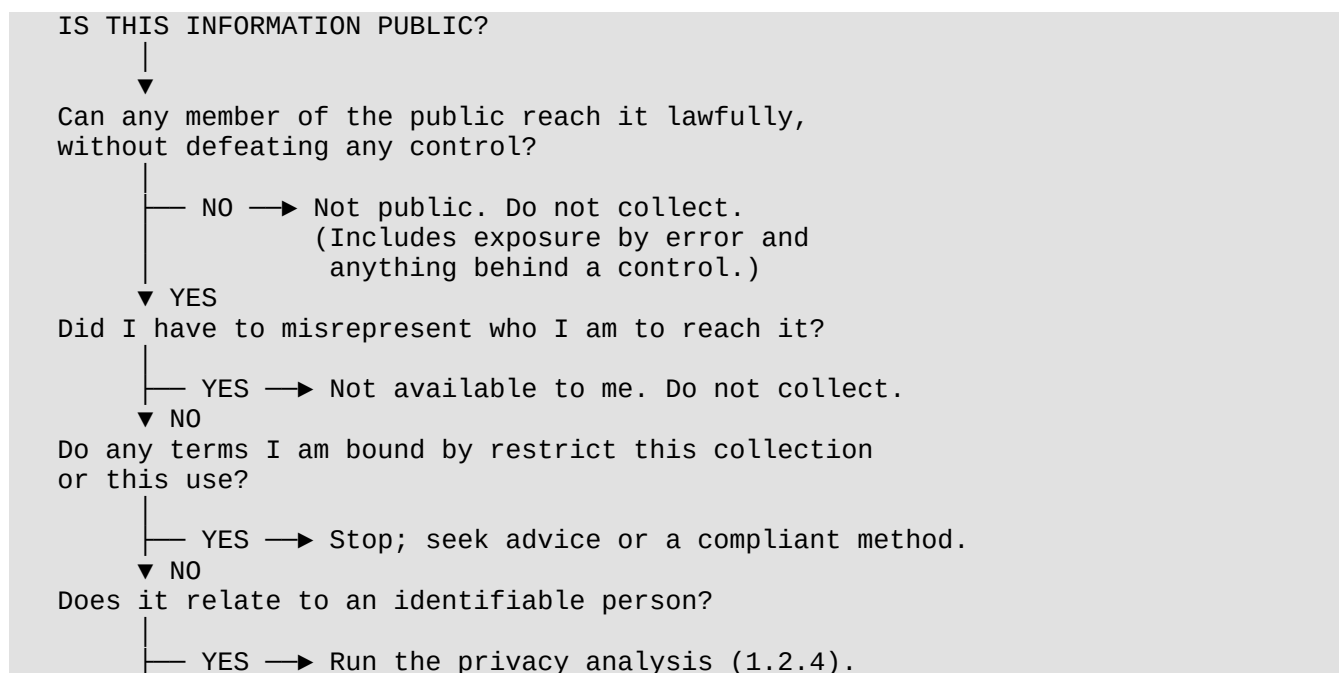
Three sets of rights survive publication:

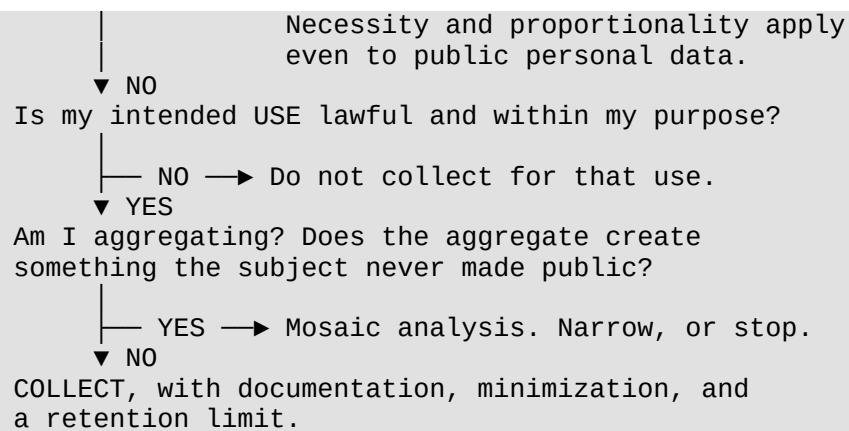
Copyright subsists in most published expression. A public article is public and copyrighted. Section 1.5 covers this.

Data protection applies to personal data regardless of whether the person made it public. In several regimes, publishing your own data does not remove others' obligations when processing it.

Contract binds you if you agreed to terms. Platform terms of service frequently restrict automated collection, reuse, and republication of material that is entirely public to view.

1.3.5 The Public Information Decision Tree





1.4 Consent

1.4.1 What Consent Is and Is Not

Consent is a person's agreement to something, given with enough knowledge and freedom for the agreement to mean anything.

Two misconceptions cause most of the trouble.

Consent is not always required. A great deal of lawful processing happens on other bases: legal obligation, contract, legitimate interests, public task. Asking "do I have consent?" when consent is not the applicable basis produces confusion in both directions, and it leads investigators either to abandon lawful work or to manufacture worthless consent.

Consent is not always available. In an investigation, telling the subject would frequently defeat the purpose. This is a recognized situation in most regimes, and the answer is not to pretend consent exists; it is to identify the basis that actually applies and to document it.

1.4.2 Types of Consent

Type	Definition	Example	Reliability
Explicit	Clearly and specifically given, usually in writing, for a stated purpose	A signed authorization to run a background check for a named purpose	Highest, if genuinely informed and freely given
Implied	Reasonably inferred from conduct in context	Handing a document to someone implies they may read it	Real but narrow; covers only what the context supports
Informed	Given with adequate understanding of what is agreed to, by whom, for what, and with what consequences	A research participant who has read a plain-language information sheet	The quality standard that explicit consent should meet

Type	Definition	Example	Reliability
Inferred (by the collector)	The collector decides consent exists from circumstances	"They posted it publicly, so they consented to my compiling it"	Not consent. This is the collector deciding on the subject's behalf
Blanket	Broad agreement to unspecified future uses	A sweeping clause in terms of service	Weak; frequently unenforceable for sensitive processing and ethically thin
Coerced or conditioned	Given under pressure, or as the price of something unrelated	"Agree or you cannot use the service you need"	Not freely given; frequently invalid

Inferred consent is the one to watch. Publishing something publicly is not consent to its aggregation, analysis, retention, or use in an investigation. A person who posts a photograph has consented to people seeing a photograph.

1.4.3 What Valid Consent Requires

Element	Test
Freely given	Was there a real choice, without penalty for refusal?
Specific	To what, exactly? Consent to one purpose is not consent to another
Informed	Did they know who, what, why, for how long, and with what consequences?
Unambiguous	A clear affirmative act, not silence or a pre-ticked box
Capable	Did they have capacity to consent? Minors and vulnerable adults raise specific issues
Revocable	Can they withdraw, and is withdrawal as easy as giving?
Documented	Can you show what they agreed to and when?

1.4.4 When Consent Is and Is Not the Question

Situation	Is consent the question?	What is
Researching a company's public filings	No	Nothing; corporate records are not personal data
Interviewing a witness	Yes, for the interview and any recording	Their agreement, informed, and recording consent specifically

Situation	Is consent the question?	What is
Reviewing an employee's work email in an internal investigation	Usually not consent	Employer policy, notice, applicable employment and privacy law
Collecting public social posts about a company	Not for the company; possibly for identifiable individuals	Necessity, proportionality, and lawful basis
Using a client's own records	No	The client's authority to give them to you, and their basis for holding them
Publishing a person's identity	No; consent would not cure it	Public interest, verification, harm, and defamation exposure
Academic research involving human subjects	Yes, and formally	Ethics committee approval and informed consent procedures
Testing a system you do not own	Yes, and it must be explicit and written	Written authorization defining scope; without it, do not touch it

That last row is worth emphasizing because it is where technically skilled students get into serious trouble. Probing, scanning, or testing a system you do not own, without written authorization defining the scope, is unauthorized access in most jurisdictions. Good intentions are not a defence and neither is the absence of damage.

1.4.5 Consent in the Investigative Context

Three practical positions:

Where consent applies, get it properly. Specific, informed, documented, and limited to a stated purpose.

Where consent does not apply, say what does. Write down the basis you are relying on and why. "Legitimate interests, balanced as follows" is a defensible sentence; silence is not.

Never manufacture consent. Do not construct an argument that a subject consented by posting publicly, by using a service, or by not objecting to something they did not know about. If you find yourself building that argument, the honest conclusion is that you do not have consent and must rely on something else or stop.

1.5 Copyright

1.5.1 Why Copyright Matters to Investigators

Investigators collect other people's expression constantly: articles, photographs, documents, videos, code, and web pages. Copyright is the body of law that governs copying and reuse of that expression, and it applies to public material as much as to private.

Two distinct exposures:

Collection and internal use. Capturing and retaining material for analysis is generally the lower-risk activity, and in many jurisdictions there are exceptions covering research, reporting, and legal proceedings. It is not automatically permitted, and the scope of any exception varies.

Republication. Putting the material into a report, a briefing, an article, or a public product is the higher-risk activity, because it is the reproduction and distribution that copyright most directly restricts.

1.5.2 The Basics

Concept	Plain description
What is protected	Original expression fixed in a tangible form: text, images, video, audio, software, compilations with original selection or arrangement
What is not protected	Facts, ideas, procedures, and in most systems short titles and names. The facts in an article are not copyrighted; the article's expression of them is
How it arises	Automatically on creation in most systems; registration may be required for certain remedies
Who owns it	The author, or their employer for work made in the course of employment, or whoever it was assigned to
Duration	Long, and varies by jurisdiction and work type. Assume in copyright unless established otherwise
Moral rights	In many jurisdictions, rights of attribution and integrity that persist separately from economic rights
Database and sui generis rights	Some jurisdictions protect substantial investment in compiling a database separately from copyright in its contents

The fact-expression distinction is the investigator's most useful principle. You may report that a filing states a revenue figure. You may not reproduce three paragraphs of a journalist's article describing it. Paraphrase in your own words, cite the source, and quote sparingly and briefly where the exact wording matters.

1.5.3 Exceptions: Fair Use, Fair Dealing, and Others

Jurisdictions handle exceptions differently, and the differences are substantial.

Fair use (United States and a few others) is an open-ended, case-by-case analysis weighing four factors:

Factor	Question	Tends to favour use when
Purpose and character	What is the use for, and is it transformative?	Non-commercial, educational, research, criticism, news reporting, or transformative
Nature of the work	What kind of work is it?	Factual rather than creative; already published
Amount and substantiality	How much was used, and was it the heart of the work?	A small portion, no more than needed
Effect on the market	Does the use substitute for the original?	No market substitution and no licensing harm

Fair dealing (United Kingdom, Canada, Australia, and others) is a closed list of permitted purposes, such as research and private study, criticism and review, news reporting, and quotation, each with its own conditions. It is narrower and more predictable than fair use.

Other exceptions commonly include text and data mining for research in some jurisdictions, use in judicial proceedings, and library and archive provisions.

The practical position for investigators: rely on the fact-expression distinction and paraphrase; quote briefly with attribution where wording matters; keep full copies internally as evidence and label them as such; and get advice before republishing anything substantial.

1.5.4 Public Domain and Open Licensing

Public domain material is not protected by copyright, because the term has expired, it was never eligible, or the rights were dedicated to the public. In some jurisdictions certain government works are in the public domain, and in others they are not. Do not assume.

Creative Commons and open licences are grants of permission on stated terms, not abandonments of copyright. Common elements:

Element	Meaning
BY (attribution)	Credit the author as specified
SA (share-alike)	Derivatives must carry the same licence
NC (non-commercial)	No commercial use; commercial is broader than people expect and can include internal business use
ND (no derivatives)	No adaptations; a cropped or annotated image may be a derivative
CC0	A dedication to the public domain, as far as the law allows

Two traps. NC is broader than "selling it," and a client-facing investigative report is frequently

commercial. ND catches annotation and cropping, which investigators do routinely.

1.5.5 Copyright in Practice for an Investigation

Situation	Position
Capturing a web page as evidence	Generally low risk as internal evidence; label as evidence, do not republish
Including a screenshot in a client report	Higher risk. Use the minimum necessary, attribute, and consider whether a description would serve
Quoting an article	Brief, attributed, and only where the wording matters. Paraphrase the rest
Using a photograph of a person or product	Two issues at once: copyright in the photograph, and privacy or publicity rights in the subject
Reproducing a leaked document	Copyright is the least of the issues; provenance, lawfulness of receipt, and privacy dominate
Using a competitor's product images	Copyright plus trade mark considerations
Building a database of collected material	Consider database rights and terms of service as well as copyright
Publishing a research dataset	Get advice. Licensing, privacy, and contract all apply

1.6 Data Retention

1.6.1 Data Is a Liability

The instinct of every investigator is to keep everything, because you might need it. The professional position is the opposite: **data you hold is data you must protect, may be compelled to produce, and can lose.**

Holding data creates	Because
Security obligation	You must protect it, and a breach is your breach
Legal exposure	It may be discoverable, subpoenaed, or subject to access requests
Compliance obligation	Retention beyond the purpose breaches storage limitation principles
Harm potential	Personal data you hold can harm people if it leaks
Cost	Storage, access control, verification, and administration

The corollary: disposal on schedule is a professional act, not a failure of diligence.

1.6.2 Retention Drivers

Retention periods are not chosen by preference. They are derived from:

Driver	Effect
Purpose	Keep only while the purpose is live
Legal obligation	Some records must be kept for a defined period (tax, employment, sector rules)
Limitation periods	Material relevant to a potential claim may need retention until the limitation period expires
Litigation hold	An overriding obligation to preserve when litigation is reasonably anticipated. A hold suspends the schedule entirely
Contract	Client agreements frequently specify retention and return or destruction
Regulatory guidance	Sector regulators often specify minimums or maximums
Data protection principles	Storage limitation requires a defined period and deletion after it

Litigation hold is the one that catches people. Routine disposal of material relevant to anticipated litigation, after the obligation attaches, is a serious problem. If litigation is in prospect, the schedule stops until counsel says otherwise, and this must be written into the plan.

1.6.3 A Retention Schedule

Data class	Example	Typical driver	Retention	Disposal method
Case administration	Plan, authorization, closure memo	Business and audit	Long	Secure deletion or archive
Evidence: non-personal	Corporate filings, imagery	Purpose and limitation period	Medium	Secure deletion
Evidence: personal data	Captures identifying individuals	Purpose, minimized	Short as practicable	Verified secure deletion
Evidence: sensitive data	Anything in a special category	Purpose, strictly minimized	Shortest practicable	Verified secure deletion, documented
Work product	Timelines, charts, matrices	Business and audit	Medium	Secure deletion
Final report	The product	Client contract,	Long	Per contract

Data class	Example	Typical driver	Retention	Disposal method
		limitation period		
Incidental third-party data	Bystanders, unrelated individuals	None; should not have been retained	Delete on identification	Immediate, documented
Superseded working copies	Drafts, intermediate exports	None	Delete at closure	Documented

Note the last two rows. Incidental third-party data is deleted as soon as it is recognized, not at closure. And working copies proliferate; a closure step that hunts them down is the difference between a schedule and a wish.

1.6.4 Secure Disposal

Method	Appropriate for	Notes
File deletion	Nothing, on its own	Deleted files are typically recoverable
Secure overwrite	Files on conventional storage	Effective for the specific file if the tool is sound
Cryptographic erasure	Encrypted volumes	Destroy the key; effective if encryption was properly implemented from the start
Full-device wipe	Devices being retired or reassigned	The reliable method for whole devices
Physical destruction	Failed drives, high-sensitivity media	Certificate of destruction where available
Paper shredding	Physical documents	Cross-cut minimum
Deletion by a third party	Cloud services, contractors	Confirm contractually and obtain confirmation; verify what "deletion" means in their service

Two problems investigators forget. Backups are copies, and a deletion that leaves backups intact has not deleted anything; the schedule must address backup expiry. And cloud synchronization propagates files to places you did not choose, which is one of several reasons Chapter 6 required deliberate storage decisions.

Every disposal is recorded: what, when, by whom, by what method, under what authority, and how it was verified.

1.7 Jurisdiction

1.7.1 Why Jurisdiction Is Hard

An OSINT investigation routinely touches several legal systems at once without anyone noticing. The investigator is in one country, the subject in another, the platform incorporated in a third, the servers in a fourth, the data subjects in a fifth, and the client in a sixth. Each may have a claim to regulate what happens.

1.7.2 How Jurisdiction Arises

Basis	Principle	Investigative example
Territorial	Conduct occurring in the territory	You are physically in country A when you collect
Effects	Conduct outside the territory with substantial effects inside it	Your collection affects people in country B
Nationality	The actor's nationality or place of establishment	Your firm is established in country C
Targeting	Deliberately directing activity at a territory	Your service is offered to clients in country D
Data location	Where the data is stored or processed	The platform's servers are in country E
Data subject location	Where the affected individuals are	Modern data protection regimes commonly use this
Contractual	Terms specifying governing law and forum	The platform's terms name a jurisdiction

The consequence: several regimes can apply simultaneously, and they can conflict. Compliance with one is not a defence to another.

1.7.3 Levels of Jurisdiction

Level	Typical scope	Investigative relevance
Local (municipal, county)	Records, permits, licensing, local ordinances	Most records research happens here; determines which office holds what
State or provincial	Corporate registration, licensing, many privacy statutes, most litigation	The most consequential level for US-facing investigative work
National	Computer misuse, data protection, copyright, sector regulation, criminal law	Where the serious constraints sit
Supranational or regional	Regimes covering multiple	Applies by data subject location

Level	Typical scope	Investigative relevance
	states, such as EU data protection	in many cases, regardless of where you are
International	Treaties, mutual legal assistance, conventions	Rarely directly usable by a private investigator; relevant when authorities are involved

1.7.4 Cross-Border Mechanisms and Frictions

Mechanism	What it does	Practical note
Mutual legal assistance treaties	Formal government-to-government evidence requests	Slow, and available only to authorities
Letters rogatory	Judicial requests for assistance abroad	Slow, formal, court-driven
Cross-border data transfer rules	Restrict moving personal data to other jurisdictions	Affects where you store your case file and which providers you use
Blocking statutes	Prohibit compliance with certain foreign legal demands	Create genuine conflicts of law
Cloud and extraterritorial access laws	Address access to data held abroad by domestic providers	An active and shifting area
Platform terms and forum clauses	Contractually specify governing law	Bind you if you agreed

The practical takeaway for an investigator: you cannot resolve a cross-border legal question by reading. You can recognize that you have one, and you can plan collection and storage to reduce how many jurisdictions you implicate.

1.7.5 A Jurisdictional Assessment

Run this at planning, not at execution. It belongs in the Chapter 6 plan.

1. WHERE AM I when I collect? (physical and network)
2. WHERE IS THE SUBJECT located or established?
3. WHERE ARE THE DATA SUBJECTS located?
4. WHERE IS THE PLATFORM established, and what do its terms specify?
5. WHERE IS THE DATA stored and processed, including my own storage?
6. WHERE IS MY CLIENT, and where will the product be used?
7. WHERE WOULD ANY PROCEEDING be brought?



LIST every jurisdiction implicated.
For each: what regime plausibly applies to what I plan?

▼
Where two or more conflict, or where any is unclear:
ESCALATE to counsel before collecting.

↓
▼
Where possible, NARROW: collect less, store in fewer
places, avoid implicating jurisdictions you do not need.

1.8 Responsible Disclosure

1.8.1 The Situation

Sometimes an investigation finds a vulnerability, an exposure, or a leak: an unsecured database, a misconfigured server, credentials in a public repository, a flaw in a product. The finder now holds information that could be used to cause harm, and the question is what to do with it.

Responsible disclosure, more precisely **coordinated vulnerability disclosure (CVD)**, is the practice of reporting the issue privately to the party who can fix it, giving them a reasonable opportunity to do so, and coordinating any public disclosure.

1.8.2 The Disclosure Models

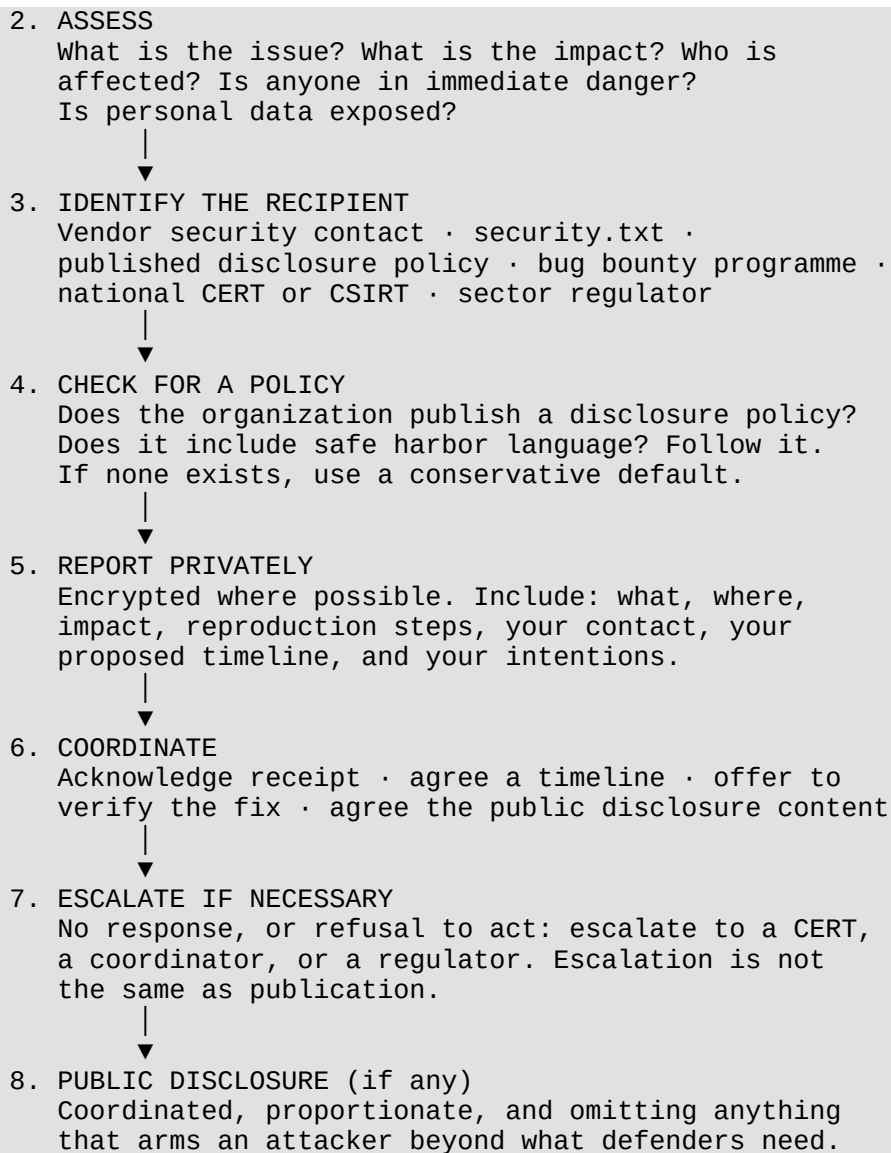
Model	Description	Argument for	Argument against
Full (immediate) disclosure	Publish everything at once	Users can defend themselves; pressure to fix	Attackers get it at the same time as defenders
Coordinated disclosure	Private report, fix window, then coordinated publication	Balances fix time against user awareness; the mainstream standard	Depends on the vendor engaging in good faith
Non-disclosure	Report privately, never publish	Minimizes attacker awareness	No public accountability; issues can persist unfixed
Sale or exploitation	Sell or use the finding	(No legitimate argument in this context)	Unethical and frequently criminal

Coordinated disclosure is the professional standard, and international standards exist describing the process for both finders and vendors.

1.8.3 The Coordinated Disclosure Process

1. DISCOVERY
Stop. Do not explore further than necessary to establish the issue exists. Do not access data. Do not test destructively. Record what you did, exactly, with times.





1.8.4 Timelines

Common practice uses a disclosure window measured in days, frequently in the range of 45 to 90 days, extendable by agreement where a fix is genuinely in progress and shortened where the issue is already being exploited.

Factor	Shortens the window	Lengthens it
Active exploitation	Yes, substantially	
Severity and exposure of personal data	Yes	
Vendor engaging constructively		Yes
Complex fix requiring coordination across parties		Yes
Vendor unresponsive or hostile	Escalate rather than shorten	

Factor	Shortens the window	Lengthens it
Fix requires physical or supply-chain action		Yes

State your timeline in the first message. Ambiguity about when you intend to publish is the single most common cause of disclosure relationships breaking down.

1.8.5 The Legal Risk to the Finder

This is the part students are not warned about often enough. **Finding and reporting a vulnerability carries real legal risk in many jurisdictions**, because the activity that discovered it may constitute unauthorized access, and because vendors occasionally respond to reports with legal threats rather than fixes.

Risk-reducing practices:

- **Do not go further than necessary.** Establishing that a database is unsecured does not require downloading it. Establishing that a flaw exists does not require exploiting it fully.
- **Never access, download, or retain third-party personal data.** If you have inadvertently retrieved some, say so, do not keep it, and document the deletion.
- **Do not test systems you do not own without written authorization.**
- **Check for a published policy and safe harbor language** before acting, and follow it exactly.
- **Document everything** contemporaneously, including what you did not do.
- **Report through a coordinator** (a national CERT or a recognized coordination body) where the vendor is unknown, unresponsive, or likely to react badly.
- **Get advice** before reporting anything with significant exposure, and certainly before publishing.

Safe harbor language in a published disclosure policy is a commitment by the organization not to pursue legal action against good-faith researchers acting within the stated scope. It is valuable and it is not universal, and its protection extends only as far as the policy's scope.

1.8.6 Exposure of Personal Data

Where the finding is exposed personal data rather than a software flaw, additional considerations apply:

- The organization may have a legal notification obligation with a statutory clock, and your report may start it.
- Affected individuals may be at risk of harm now.
- Regulators may need to be informed by the organization, and in some circumstances a finder may be able to notify a regulator directly.
- **You should not download the exposed data.** Establish enough to describe it accurately (type, approximate volume, sample field names), and no more.

- Any content you did retrieve is a liability in your hands, subject to Chapter 6 custody and this chapter's retention rules, and should be disposed of when it is no longer needed with the disposal documented.

1.9 Legal Limitations

1.9.1 The Categories

A survey of the areas that constrain investigative work. Each is a concept to recognize, not a rule you can apply from a paragraph.

Area	What it restricts	Typical investigative trigger
Computer misuse and unauthorized access	Accessing systems, accounts, or data without authorization, or exceeding authorization	Logins, credential use, scanning, probing, bypassing controls, sometimes automated collection
Interception and communications privacy	Intercepting communications you are not party to; recording calls	Any interception; recording without required consent
Data protection and privacy	Processing personal data	Nearly all investigative work touching people
Sector-specific data rules	Health, financial, credit, education, and children's data	Any dataset touching these categories
Consumer reporting rules	Using information for decisions about employment, credit, insurance, or housing	Background checks, tenant screening, hiring research
Trade secret and confidentiality	Acquiring or using another party's protected information	Insider-provided documents, competitor information
Anti-stalking, harassment, and protective orders	Course-of-conduct surveillance and contact directed at a person	Repeated attention to an individual, however lawful each step
Defamation	Publishing false statements harming reputation	Any published identification or allegation
Impersonation and pretexting	Obtaining information by misrepresenting identity, and obtaining certain records by deception	False personas, social engineering
Contract and terms of service	What you agreed to	Automated collection, account creation, reuse of platform data
Copyright and database rights	Copying and reuse of protected expression and compilations	Republication, dataset building
Export control and sanctions	Dealings with sanctioned parties and controlled technology	Cross-border work, certain technical tooling

Area	What it restricts	Typical investigative trigger
Evidence and procedure rules	How evidence must be handled to be usable	Anything destined for a proceeding
Licensing	Whether the activity requires a licence (private investigator licensing exists in many jurisdictions)	Investigative work for hire

Two of these surprise people. Private investigator licensing is required in many jurisdictions for investigative work performed for others, and doing it unlicensed is itself an offence in those places. And anti-stalking provisions can be engaged by a course of conduct composed entirely of individually lawful acts, which is precisely the shape of an aggressive OSINT investigation directed at an individual.

1.9.2 The Recurring Traps

Trap	Why it catches people
"It was publicly accessible"	Confuses accessibility with authorization
"I did not cause any damage"	Damage is not an element of many access offences
"I was going to report it"	Intent to report is not authorization to access
"The terms are unenforceable"	Not your determination to make while collecting
"It is only metadata"	Metadata is personal data in many regimes and is highly revealing
"Anyone could have found it"	Irrelevant to whether you were permitted to
"The client said it was fine"	The client cannot authorize what they do not control
"It is for a good purpose"	Purpose affects some analyses and no offences
"I did not keep it"	Collection is frequently the regulated act
"It is a public figure"	Narrows some protections, eliminates none

1.9.3 Risk Mitigation

Risk	Mitigation
Unauthorized access	Never touch a system you do not own without written authorization defining scope
Terms breach	Read the terms for every platform in scope; record the position per platform in the plan
Data protection breach	Minimize, document the basis, restrict access,

Risk	Mitigation
	retain briefly, dispose verifiably
Sensitive data exposure	Do not collect special categories; if encountered, record the encounter and exclude
Defamation	Characterize precisely, never assert intent, distinguish allegation from finding, verify before naming
Third-party harm	Individuals policy, minor exclusion, incidental data deleted on identification
Jurisdictional conflict	Assessment at planning; narrow the footprint; escalate conflicts
Licensing	Confirm whether your activity requires a licence where you operate, before you operate
Evidence unusable	Chapter 6 custody discipline from the first item
Client instruction to overstep	Written scope, written prohibited activities, and a documented refusal if it comes to that
Disclosure retaliation	Follow published policy, use a coordinator, get advice, document everything

1.10 Investigative Ethics

1.10.1 The Professional Standards

Most investigative professions have published codes: competitive intelligence, journalism, security research, law enforcement, academic research, and licensed investigation each have their own. They differ in detail and converge on a small set of commitments.

Commitment	In practice
Honesty about identity	Do not misrepresent who you are or who you work for
Lawfulness	Operate within the law, and escalate where unclear
Accuracy	Verify before asserting; distinguish fact, evidence, and inference
Proportionality	Use the least intrusive method adequate to the purpose
Minimization	Collect and keep only what is necessary
Fairness to subjects	Apply the same standard to evidence that helps and harms your client's position

Commitment	In practice
Confidentiality	Protect what you hold, including about people who are not your subject
Independence	Do not shape findings to the client's preference
Accountability	Document, and be prepared to explain every decision
Harm avoidance	Consider the consequences for people who did not choose to be involved

1.10.2 Ethical Decision Frameworks

When a situation is genuinely difficult, a framework structures the reasoning and, importantly, produces a record of it.

Framework 1: The five-question test (fast, for routine decisions).

1. Is it lawful?
2. Am I authorized?
3. Is it necessary and proportionate to a stated purpose?
4. Who could be harmed, and how badly?
5. Would I be comfortable if everyone involved saw exactly what I did and why?

Framework 2: Multi-lens analysis (for genuine dilemmas). Run the situation through four lenses and note where they disagree:

Lens	Asks	Weakness
Consequences	What outcome produces the most good and least harm, across everyone affected?	Can justify harming a few for many; requires predicting outcomes
Duties and rights	What obligations do I have regardless of outcome? Whose rights are engaged?	Can produce rigid answers that ignore consequences
Character	What would a person of professional integrity do here?	Vague without a community of practice to reference
Fairness	Is the burden distributed justly? Would I accept this if I were the subject?	Silent on some technical questions

Where the lenses agree, act. Where they disagree, the disagreement is the substance of the dilemma and must be documented, escalated, and decided deliberately rather than by default.

Framework 3: The stakeholder map (when many parties are affected). List every affected party,

what they stand to gain and lose, whether they consented, and whether they can protect themselves. Parties who did not consent and cannot protect themselves get the most weight.

1.10.3 Ethical Failure Modes

Failure	Description
Capability creep	Doing something because you can, after learning you can
Purpose drift	Data collected for one purpose used for another without a decision
Moral licensing	A good purpose treated as authorization for questionable means
Diffusion of responsibility	"The client asked for it," "the tool did it," "everyone does this"
Abstraction	Treating subjects as data points rather than as people who will experience the consequences
Certainty	Believing you already know the answer, which suspends the framework
Normalized deviance	Small departures becoming standard because nothing bad happened yet
Selective rigour	Applying strict standards to evidence that hurts your client's case and loose ones to evidence that helps

Normalized deviance is the most dangerous because it is invisible from inside. The remedy is external: periodic review by someone not on the case, and written standards that a person can be held to rather than norms that drift.

1.10.4 Duties to Different Parties

Party	Duty
The client	Competence, honesty, independence, confidentiality, and the courage to deliver an unwelcome finding
The subject	Accuracy, proportionality, fairness, and the same standard of evidence you would want applied to yourself
Third parties	Minimization and exclusion; they did not choose to be near this
The public	Where the work affects public interests, an obligation not to mislead
The profession	Not to make the field less trusted than you found

Party	Duty
	it
Yourself	A record of your reasoning, and a line you will not cross for any client

The last row is not sentimental. Decide, in advance and in writing, what you will refuse. The decision is much harder to make for the first time at 5pm on a Friday with a client on the phone.

1.10.5 When to Refuse and How

Refusal is a professional skill. The structure:

1. **State clearly what you will not do**, and be specific.
2. **Give the reason**, in terms of law, professional standards, or engagement scope, not personal preference.
3. **Offer the lawful alternative**, if there is one. Most requests that cross a line have a compliant version that answers most of the underlying need.
4. **Put it in writing.** A refusal that exists only in a conversation did not happen.
5. **Escalate if pressed.** To your supervisor, to counsel, or to the client's counsel.
6. **Be prepared to withdraw.** Record the reason for withdrawal factually.

Part 2: Comparison Tables

2.1 Legal vs. Ethical Conduct

Dimension	Legal	Ethical
Question asked	Is this permitted?	Is this right?
Source	Statute, regulation, case law, contract, terms	Professional codes, standards of practice, moral reasoning
Standard	The minimum a society enforces against everyone	What a competent professional holds themselves to
Coverage	Narrow; most daily conduct is unaddressed	Broad; covers the judgment calls law is silent on
Determinacy	Often determinable with advice	Frequently requires judgment about specific facts
Enforcement	Courts, regulators, prosecutors, counterparties	Professional bodies, employers, colleagues, self
Consequence of breach	Liability, prosecution, sanction,	Harm to a person, lost trust, and

Dimension	Legal	Ethical
	inadmissibility	sometimes nothing external
Speed of change	Years behind practice	Continuous, through professional discourse
Varies by	Jurisdiction, sector, role	Profession, context, relationship to the subject
Who decides in the moment	Ultimately a court	You, alone, usually unreviewed
Relationship	The floor	The standard
Failure signature	An action that was prohibited	An action that was permitted and should not have been taken
Example of divergence	Compiling a private individual's full profile from public posts: lawful in many places, and surveillance	

2.2 Public Information vs. Private Information

Dimension	Public	Private
Accessibility	Reachable by any member of the public without defeating a control	Requires credentials, permission, or circumvention
Examples	Corporate registries, court opinions, property records, published filings, press releases, public posts	Direct messages, account contents, internal documents, health records, unlisted files
Legal collection	Generally permitted subject to authority, purpose, and terms	Generally prohibited without authorization
Copyright	Still applies	Still applies
Data protection	Still applies to personal data	Applies
Terms of service	May restrict collection and reuse	Access itself is typically prohibited
The recurring error	Treating accessibility as authorization	Treating a weak control as no control
Grey areas	Practical obscurity, default-public platform settings, aggregation	Material exposed by error, which is not private in appearance and is not public in fact
Exposed by error	Not public. Availability by mistake is not publication	Treat as private; do not collect; consider disclosure (Section 1.8)
The correct question	Not "is it public?" but "am I authorized, is it necessary, is it	

Dimension	Public	Private
	proportionate, and should I?"	

2.3 PII vs. Non-PII

Dimension	PII / personal data	Non-PII / non-personal data
Definition	Relates to an identified or identifiable individual	Does not relate to an identifiable individual
Direct identifiers	Name, government ID number, email address, phone number, account number	
Indirect identifiers	IP address, device ID, cookie ID, licence plate, employee number, precise location	
Quasi-identifiers	Postcode, date of birth, gender, occupation, employer, which in combination identify	
Examples of non-personal	Aggregate statistics with suppressed small cells, weather, corporate financials, geological data	
Regulated?	Yes, in most modern regimes	Generally not as personal data
Sensitive subset	Health, biometric, genetic, racial or ethnic origin, religion, political opinion, union membership, sexual orientation, criminal history	Not applicable
Handling	Lawful basis, minimization, retention limit, access control, individual rights	Ordinary business handling; other rules may apply
Pseudonymized	Still personal data; re-identifiable with the key	
Anonymized	Outside the regime, if genuinely irreversible	Effectively non-personal, if the claim is justified
The trap	Assuming that removing names makes data non-personal	Assuming aggregate data cannot re-identify small groups
Investigator's rule	If a person could be picked out, treat it as personal data	

2.4 Explicit vs. Implied Consent

Dimension	Explicit	Implied	Inferred by the collector
How given	A clear affirmative act, usually written	Reasonably inferred from conduct in context	Not given; assumed by the collector
Scope	What was specifically stated	Only what the context supports	Whatever the collector decides
Evidence of it	A signed form, a recorded agreement, a logged affirmative action	Contemporaneous record of the conduct and context	None
Example	Signed authorization for a background check for a named purpose	Handing someone a document implies they may read it	"They posted publicly, so they consented to my profiling them"
Revocable	Yes, and withdrawal should be as easy as giving	Yes, by changed conduct	Not applicable
Adequate for sensitive data	Sometimes, if specific and informed	No	No
Adequate for recording an interview	Yes, and required in many jurisdictions	No	No
Adequate for system testing	Yes, and must be written with scope defined	No	No
Validity risks	Not freely given; not specific; not informed; bundled with unrelated terms	Overreading the context	It is not consent at all
Investigator's rule	Get it in writing, specific to purpose, and keep it	Rely only on what the context genuinely supports	Never rely on it. Identify the basis that actually applies

2.5 Copyright, Fair Use, Public Domain, and Creative Commons

Dimension	Copyright	Fair use / fair dealing	Public domain	Creative Commons
What it is	Exclusive rights in original expression	An exception permitting some unlicensed use	Material with no subsisting copyright	A licence granting permission on stated terms
Arises	Automatically on creation	By operation of law, assessed case	On expiry, ineligibility, or	By the rights holder's choice

Dimension	Copyright	Fair use / fair dealing	Public domain	Creative Commons
		by case (fair use) or within a closed list (fair dealing)	dedication	
Permission needed	Yes, unless an exception applies	No, but the exception must actually apply	No	No, if you comply with the terms
Attribution required	Depends; moral rights may require it	Good practice, and relevant to the analysis	Not legally, and expected professionally	Yes, under BY terms
Commercial use	Requires permission	Weights against fair use but is not fatal	Permitted	Prohibited under NC terms, and "commercial" is broader than selling
Derivatives	Requires permission	May be permitted, especially where transformative	Permitted	Prohibited under ND; must match licence under SA
Predictability	High	Low for fair use, moderate for fair dealing	High, once verified	High, if the licence is genuine and applies to the item
Investigative use: internal evidence	Generally lower risk; label as evidence	Frequently the applicable analysis	No issue	No issue
Investigative use: republication	The high-risk activity	Must be assessed before publishing	No issue	Comply with terms
Common trap	Assuming public means free	Assuming any research use qualifies	Assuming government works are always public domain; jurisdictions differ	Assuming NC excludes only sales, or that cropping is not a derivative
Safest practice	Paraphrase facts, quote briefly with attribution, get advice before republishing substantially			Check the specific licence version and that it applies to the specific item

2.6 Local vs. National vs. International Jurisdiction

Dimension	Local	State / provincial	National	Supranational / international
Typical scope	Municipal and county ordinances, records, licensing	Corporate law, most litigation, many privacy statutes, professional licensing	Computer misuse, data protection, copyright, criminal law, sector regulation	Regional regimes, treaties, mutual legal assistance
Investigative relevance	Where most records physically live	The most consequential level for records and licensing	Where the serious prohibitions sit	Applies by data subject location or by treaty
How it reaches you	Physical presence, property, local activity	Establishment, activity, targeting	Territory, nationality, effects, targeting	Data subject location, establishment, targeting
Typical questions	Which office holds the record? Is there a local ordinance?	Do I need a licence? Which court?	Is this access authorized? Which data protection rules apply?	Does a foreign regime reach my processing?
Conflict potential	Low	Moderate	High	Highest; blocking statutes and conflicting obligations
Resolution mechanism	Local counsel	State counsel	National counsel	Specialist advice; frequently no clean answer
Investigator's action	Determine the jurisdiction before searching (Chapter 3)	Confirm licensing before operating	Assess before collecting	Map at planning; narrow the footprint; escalate conflicts
Common error	Searching the wrong level and reporting a false negative	Assuming a home-state licence travels	Assuming the law where you sit is the only law that applies	Assuming compliance with one regime is a defence to another

2.7 Responsible vs. Irresponsible Disclosure

Dimension	Responsible (coordinated)	Irresponsible
Initial action on discovery	Stop; establish existence with minimum access	Explore, enumerate, download, test further

Dimension	Responsible (coordinated)	Irresponsible
Third-party data	Not accessed, not retained	Downloaded "to prove it"
First contact	Private, to the party who can fix it, through a published channel where one exists	Public post, social media, or the press
Policy	Published policy located and followed	Ignored or never checked
Timeline	Stated up front, reasonable, negotiable in good faith	Absent, or an ultimatum
Communication	Professional, factual, reproducible, offering to verify a fix	Accusatory, vague, or demanding payment
Escalation	To a CERT, coordinator, or regulator when the vendor is unresponsive	Straight to publication
Public disclosure content	Proportionate; enough for defenders, not a working exploit against unpatched systems	Full detail regardless of patch status
Payment	Only through a published bounty programme	Demanding payment for silence, which is extortion
Documentation	Contemporaneous record of every action and non-action	None
Legal posture	Advice taken; safe harbor checked; conduct within scope	No advice; conduct outside any policy
Outcome	Issue fixed, users protected, finder's reputation enhanced	Users exposed, relationships destroyed, finder exposed to liability

2.8 Ethical vs. Unethical Investigative Practices

Practice area	Ethical	Unethical
Identity	Accurate representation of who you are	False personas, pretexting, impersonation
Access	Only what is lawfully available to you	Circumvention, credential use, exploiting an exposure
Sources	Lawfully obtained, documented, evaluated	Insider material, purchased personal data, exposure by error
Scope	Bounded by a stated requirement, with exclusions	Unbounded curiosity; drift toward individuals
Subjects	Individuals appear only in a	Profiles of private persons;

Practice area	Ethical	Unethical
	relevant capacity	family; minors
Aggregation	Mosaic effect considered and constrained	Assembling everything because each part was public
Evidence handling	Same standard for helpful and unhelpful evidence	Selective rigour
Characterization	Allegation, finding, and inference distinguished	Assertions of intent and guilt from structure
Confidence	Stated, calibrated, and lowered when appropriate	Overstated to satisfy the client
Third parties	Minimized, excluded, deleted on identification	Retained because they might be useful
Client relations	Independence; unwelcome findings delivered	Findings shaped to the client's preference
Refusal	Documented, with a lawful alternative offered	Compliance with an improper instruction
Retention	Minimized, scheduled, disposed of verifiably	Kept indefinitely "just in case"
Documentation	Complete, including what was declined	Records only what supports the conclusion

2.9 Data Retention vs. Secure Data Disposal

Dimension	Retention	Disposal
Purpose	Keep what is needed, for as long as it is needed	Remove what is no longer needed, verifiably
Driver	Purpose, legal obligation, limitation periods, contract, litigation hold	Storage limitation, minimization, contract, risk reduction
Decided	At planning, in a schedule	At planning, executed on schedule
Unit	Data class, not individual file	Data class, executed per item
Documentation	Schedule stating class, period, and driver	Record of what, when, by whom, by what method, under what authority, and how verified
Risk of getting it wrong	Holding data creates security, discovery, and compliance exposure	Destroying material subject to a hold or a legal obligation is a serious problem
Overriding condition	A litigation hold suspends the schedule entirely	No disposal while a hold is in force

Dimension	Retention	Disposal
Backups	Frequently forgotten; a copy is a copy	Deletion that leaves backups is not deletion; address backup expiry
Third-party copies	Cloud sync and provider storage create copies you did not choose	Confirm provider deletion contractually and obtain confirmation
Methods	Access-controlled storage, encryption, integrity verification	Secure overwrite, cryptographic erasure, device wipe, physical destruction, certified shredding
Professional posture	Data is a liability as much as an asset	Disposal on schedule is a professional act, not a lapse

2.10 Common Legal Risks and Mitigation Strategies

Risk	How it arises	Consequence	Mitigation
Unauthorized access	Logging in, scanning, probing, or bypassing a control on a system you do not own	Criminal exposure; findings unusable	Never touch a system you do not own without written, scoped authorization
Terms of service breach	Automated collection, account creation, prohibited reuse	Contract claims; account termination; evidence questioned	Read terms per platform; record the position in the plan; manual collection only where required
Data protection breach	Collecting or keeping personal data without a basis, purpose, or limit	Regulatory action; individual complaints; reputational harm	Document the basis; minimize; restrict access; retain briefly; dispose verifiably
Sensitive data processing	Health, biometric, political, religious, sexual orientation, or criminal history data	Heightened regulatory exposure	Do not collect; if encountered, record the encounter and exclude
Defamation	Publishing an unverified identification or an assertion of wrongdoing	Civil liability; harm to a person	Characterize precisely; verify before naming; never assert intent; distinguish allegation from finding
Harassment or stalking exposure	A course of conduct directed at an individual, however lawful each act	Criminal exposure; protective orders	Individuals policy; no persistent attention to a private person; scope exclusions

Risk	How it arises	Consequence	Mitigation
Trade secret misappropriation	Accepting or using another party's protected information	Civil and criminal exposure	Refuse insider material; quarantine, notify counsel, document
Consumer reporting rules	Using research for employment, credit, insurance, or housing decisions	Regulatory exposure; claims by the individual	Route through the compliant process; do not do it informally
Copyright infringement	Republishing substantial protected expression	Claims; takedowns; product withdrawal	Paraphrase; quote briefly with attribution; advice before substantial republication
Jurisdictional conflict	Multiple regimes reaching the same processing	Conflicting obligations; no clean answer	Map at planning; narrow the footprint; escalate
Unlicensed investigation	Investigative work for hire in a jurisdiction requiring a licence	Offence; unenforceable contracts	Confirm licensing before operating
Evidence inadmissibility	Custody or handling failures	The work cannot be used	Chapter 6 discipline from the first item
Disclosure retaliation	Reporting a vulnerability to a hostile recipient	Legal threats against the finder	Follow published policy; use a coordinator; take advice; document everything
Client instruction to overstep	Pressure to collect beyond scope or law	Complicity; liability	Written scope and prohibited activities; documented refusal; withdrawal if necessary
Retention overexposure	Holding data indefinitely	Breach magnitude; discovery exposure	Retention schedule; scheduled disposal; documented destruction

Part 3: Case Studies

Each case sets out the dilemma, the legal considerations, the decisions, the outcome, the lessons, and the best practices. Cases marked *historical* describe real documented events in general terms; cases marked *composite* are built from documented professional practice and are not real organizations or people. Legal points are illustrative and general.

3.1 Cybersecurity: The Exposed Backup

(composite)

The situation. A security analyst at a managed service provider, conducting authorized external attack surface work for a client, discovers a storage bucket that is publicly readable. It does not belong to the client. Its file names indicate it contains database backups from a regional healthcare billing company. One file name includes the word "patients."

The dilemma. The analyst can confirm the exposure by downloading a file, which would tell them exactly what is exposed and how many people are affected, and which would place a large volume of health data in their possession. Doing nothing leaves the exposure open. The company is not their client and has no relationship with them.

Legal considerations. Accessing data on a system you are not authorized to access may constitute unauthorized access even where no control was bypassed, and jurisdictions differ on whether a misconfiguration constitutes authorization. Health data is a special category with sector-specific rules in most regimes. The company may have a notification obligation with a statutory clock. The analyst's own possession of the data would create obligations and liability.

Decisions made.

1. Stopped immediately after observing the file listing. Did not download any file, did not enumerate beyond the initial listing, and did not test write access.
2. Recorded contemporaneously: the exact URL, the timestamp, the listing as displayed, the actions taken, and explicitly the actions not taken.
3. Captured a screenshot of the file listing only, which showed file names and sizes and no content.
4. Notified their own management and counsel before contacting anyone else.
5. Searched for a published security contact or disclosure policy at the healthcare company; found none.
6. Reported through a national CERT rather than contacting the company cold, because the company had no security contact and the data category was sensitive.
7. Did not publish anything, then or later.

Outcome. The CERT contacted the company, which secured the bucket within 48 hours. The company's own investigation determined the exposure window and notified its regulator and affected individuals. The analyst's firm was neither thanked nor sued. No public disclosure was made by the finder.

Lessons.

The download would have been the error. It would have converted a clean report into a situation in which the analyst held thousands of people's health records, with no basis, no lawful purpose, and an obligation to protect and dispose of them. The additional certainty was not worth it.

Recording what you did not do is as important as recording what you did. If challenged, "we did not download, enumerate, or write, and here is the contemporaneous record" is the entire defence.

Using a coordinator was the right call for a sensitive category with no security contact. Cold-contacting an organization with no disclosure process invites a defensive reaction.

Best practices. Stop at existence. Never download third-party personal data. Record actions and non-actions. Escalate internally before externally. Prefer a coordinator where the recipient is unknown, unresponsive, or likely to react badly. Publish nothing without advice.

3.2 Investigative Journalism: The Document With a Provenance Problem

(composite, reflecting documented newsroom practice)

The situation. A reporter receives, from an anonymous source, a set of internal documents from a regional utility appearing to show that management knew about a safety deficiency for two years before an incident. The documents are internally consistent and the story is significant. The reporter does not know how the source obtained them.

The dilemma. The public interest in the story is substantial. The documents may have been obtained unlawfully by the source. Publishing may expose the source, harm the utility's legitimate confidentiality interests, and expose the newsroom to legal action. Not publishing leaves a serious safety matter unexamined.

Legal considerations. In many jurisdictions receiving and publishing material that a source obtained unlawfully is treated differently from obtaining it unlawfully oneself, and protections for publication on matters of public interest exist, but they vary substantially and are not unlimited. Personal data of individuals named in the documents is engaged. Defamation exposure attaches to every assertion. Source protection obligations are both ethical and, in some jurisdictions, legally recognized.

Decisions made.

1. Legal review before any verification steps that would reveal the newsroom's possession of the documents.
2. Verification through independent means: public regulatory filings, inspection records, and interviews, so that the story could stand on independently sourced facts rather than on the documents alone.
3. Source protection: the documents were compartmented, handling was minimized, and the record of receipt was itself protected.
4. Personal data of junior employees named in the documents was redacted from anything published; only individuals whose role made them accountable for the decisions were named.
5. Right of reply: the utility was given the substance of the findings and a reasonable period to respond, before publication.
6. Publication limited to what independent verification supported, with the documents used to

direct the reporting rather than as the sole basis for assertions.

Outcome. The story published with the core findings independently corroborated. The utility disputed characterization but not the underlying records. A regulatory review followed. No action was taken against the newsroom, and the source was not identified.

Lessons.

Independent verification changed the legal and ethical position entirely. A story resting solely on documents of unknown provenance is fragile; the same story resting on regulatory filings that the documents pointed to is robust.

Right of reply is a methodological step. It repeatedly produces information the reporter did not have, including benign explanations.

Not everyone named in a document is a public actor. Redacting junior employees cost nothing and protected people who had no decision-making role.

Best practices. Legal review early. Verify independently wherever possible. Compartment sensitive material. Redact people whose accountability is not at issue. Offer right of reply. Publish only what is supported.

3.3 Corporate Due Diligence: The Tempting Insider

(composite)

The situation. During pre-acquisition diligence on a target company, an investigator is contacted by a former employee of the target who offers internal financial records "to help you see what they are hiding." The records, if genuine, would resolve the central diligence question.

The dilemma. The material would answer the client's most important question. Accepting it may constitute misappropriation of trade secrets and may expose the acquirer to claims that would survive the transaction. Declining leaves the question open.

Legal considerations. Trade secret regimes protect information that has commercial value and that its owner took reasonable measures to keep secret. Acquiring it through a person who was not authorized to disclose it can constitute misappropriation by the recipient as well as the discloser. The former employee is likely bound by confidentiality obligations. Any transaction contaminated by such material may be challenged.

Decisions made.

1. The investigator declined to receive the material and said so in writing to the former employee, in neutral terms and without accusation.
2. Notified the client's counsel immediately, before doing anything else.
3. Documented the contact: who, when, what was offered, what was said, and what was not received.

4. Did not follow up with the former employee, and did not seek to identify what the records would have shown.
5. Reframed the diligence question: what public and compelled records could establish about the same subject, and what representations and warranties could cover the residual gap.
6. Reported to the client that a source had offered internal material, that it had been declined, and why.

Outcome. The diligence proceeded on public records. The central question was partly resolved by a regulatory filing that had not been examined, and the remainder was covered by a specific warranty and an indemnity. The transaction closed. Six months later the target's former parent raised a trade secret dispute against a different party, and the acquirer's clean record of the declined offer was material to its position.

Lessons.

Declining in writing was the valuable act. A verbal decline that was never recorded would have left the acquirer with an allegation and no evidence.

Telling the client you declined is not optional. The client needs to know that the offer was made, both because it bears on the target's situation and because the client's counsel must assess exposure.

The reframe usually works. Most questions that an improper source would answer have a partial lawful answer plus a contractual mechanism for the remainder.

Best practices. Refuse in writing. Do not accept, read, or copy. Notify counsel immediately. Document the contact. Do not pursue the source. Reframe the question. Tell the client what happened.

3.4 Law Enforcement: Social Media Monitoring of a Planned Protest

(composite, reflecting documented policy debates)

The situation. A city police department plans to monitor public social media ahead of a planned demonstration, to assess whether any credible threat of violence exists and to plan traffic and staffing.

The dilemma. Public safety planning is a legitimate function. Monitoring speech and association is precisely the activity that constitutional and human rights protections restrict, and doing it badly chills lawful expression. The information is public. The activity being observed is lawful political expression.

Legal considerations. In many democratic systems, collecting and retaining information about individuals engaged in lawful political, religious, or associational activity is restricted, frequently requiring a criminal predicate. Public availability does not remove the restriction on a state actor. Retention limits, audit requirements, and purpose limitation typically apply. Departmental policy and consent decrees may impose additional constraints.

Decisions made.

1. A written collection plan approved before any monitoring, stating the purpose (identification of

specific credible threats and operational planning), the duration, and the prohibited activities.

2. Collection limited to publicly viewable posts, with no accounts created, no follow requests, and no access to restricted content.
3. **No collection or retention about individuals absent a specific, articulable threat indicator.** Organizers' public logistics posts were used for traffic planning without retaining identity information about attendees.
4. A defined threat threshold agreed in advance, distinguishing protected speech from a true threat, with legal review of the threshold.
5. Retention: material not meeting the threshold was purged at a defined point after the event, with the purge documented.
6. Audit: every query logged with the officer and the justification.
7. Post-event review, including whether any collection had been retained that should not have been.

Outcome. No credible threat was identified. Traffic and staffing planning used organizer-published logistics. The post-event review found three queries that had been made without a recorded justification, which resulted in retraining rather than sanction, and the purge was completed and documented. The department published a summary of its approach.

Lessons.

The pre-agreed threshold is what makes this defensible. Without it, the distinction between protected speech and a threat is made in the moment by an individual officer, which is exactly the condition under which it is made badly.

Purge discipline is the visible commitment. A department that collects broadly and retains indefinitely has, in effect, built a political association database regardless of its intentions.

The audit found something, which is the point. An audit that never finds anything is not being run.

Best practices. Written plan and approved purpose. Public content only. A predicate requirement. A pre-agreed threshold with legal review. Logged queries with justifications. Defined retention with a documented purge. Post-event audit.

3.5 Academic Research: The Public Dataset That Was Not

(composite, reflecting documented research ethics controversies)

The situation. A doctoral researcher plans to study online community dynamics using posts scraped from a public forum. The posts are publicly viewable. The forum serves a support community whose members discuss personal difficulties. The researcher's institution requires ethics committee review for human subjects research.

The dilemma. The data is public and the research question is legitimate and potentially beneficial. The

community members did not post for research purposes, would likely object, and could be harmed by quotation that is searchable back to them. The platform's terms prohibit automated collection.

Legal considerations. Terms of service prohibit the collection method. Data protection regimes apply to publicly posted personal data. Research exemptions exist in some regimes and are narrower than researchers assume. Institutional policy and ethics committee approval are conditions of the work regardless of the legal position.

Decisions made.

1. Ethics committee submission before any collection, with the full method described including the terms of service conflict.
2. The committee required changes: no automated collection, given the terms; a sampling approach with manual collection; no verbatim quotation of any post, because verbatim text is searchable back to the author; and pseudonymization at the point of collection.
3. The researcher approached the community's moderators, explained the study, and sought their view. Moderators consented to the study and declined to permit any quotation, which the researcher accepted.
4. Findings were reported as aggregate patterns and paraphrased composites, with a note in the methods section explaining why no quotations appear.
5. Retention limited to the study period plus the institution's required period, with a disposal date.
6. The dataset was not published, because publication would have re-exposed the material in an aggregated and more findable form.

Outcome. The study completed and was published. The community was not disrupted. The methodological limitation (no quotations) was noted by reviewers as a constraint and accepted. A subsequent study by another group, which quoted verbatim, resulted in community members identifying themselves in the paper and a public controversy.

Lessons.

Verbatim quotation of public posts is searchable back to the author. This is the single most consequential practical point in internet research ethics and it is regularly missed.

Asking the community was the decision that made the study defensible, and it cost the researcher a method they wanted.

Public availability and research ethics are entirely separate questions. The ethics committee's jurisdiction does not depend on whether the data was public.

Best practices. Ethics review before collection. Respect terms of service. Consider searchability, not just identifiability. Engage the community where one exists. Paraphrase rather than quote. Pseudonymize at collection. Do not publish the raw dataset.

3.6 Fraud Investigation: The Complainant Who Became a Subject

(composite)

The situation. An insurer's special investigations unit is examining a claim. Mid-investigation, the investigator finds that the claimant's public social media suggests activity inconsistent with the claimed injury. The investigator's supervisor asks for "everything on this person."

The dilemma. The insurer has a legitimate interest in investigating a claim, and the claimant has contractually agreed to cooperate. "Everything on this person" is not a legitimate interest, it is a fishing expedition, and it would capture family members, health information, and material irrelevant to the claim.

Legal considerations. The insurer's basis is likely legitimate interests or contract, both of which require necessity and proportionality. Health information is a special category. Family members are third parties with no relationship to the claim. Excessive or persistent attention to an individual can engage harassment provisions. Regulatory rules for insurers frequently impose fair-handling obligations toward claimants.

Decisions made.

1. The investigator declined the "everything" instruction in writing, and offered a scoped alternative: publicly viewable material relating to physical activity within the claimed injury period, only.
2. A written proportionality assessment, recording the claim value, the specific inconsistency observed, the necessity of the collection, and the limits set.
3. Explicit exclusions: family members, health-related content, material outside the claim period, and anything relating to the claimant's political, religious, or associational activity.
4. Collection limited to public content, with no accounts created and no contact.
5. Incidental third-party material encountered was recorded as encountered and deleted, with the deletion documented.
6. The claimant was given the opportunity to explain the apparent inconsistency before any adverse determination.
7. Retention limited to the claim's lifecycle plus the regulatory period.

Outcome. The apparent inconsistency had a benign explanation that the claimant provided when asked: the activity shown predated the injury and the post was a memory shared later. The claim was paid. The written proportionality assessment and the narrow scope meant that the investigator's conduct withstood a subsequent complaint by the claimant about the investigation itself.

Lessons.

"Everything on this person" is never a legitimate instruction, and declining it in writing is what protected both the investigator and the insurer.

Asking the subject resolved it. The single most effective and least intrusive investigative step was available throughout and was nearly skipped.

Content dates and posting dates are different, which is a Chapter 4 processing point that here had a person's claim riding on it.

Best practices. Scope narrowly to the specific inconsistency. Write the proportionality assessment. Exclude family, health, and protected activity. Delete incidental third-party material. Give the subject an opportunity to explain. Retain briefly.

3.7 Vulnerability Disclosure: The Unresponsive Vendor

(historical pattern, described in general terms)

The situation. A researcher discovers a serious flaw in a widely deployed product. The vendor has no published security contact. Initial reports through general support channels go unanswered for six weeks. The flaw is exploitable and the researcher believes users are at risk.

The dilemma. Publishing arms attackers before a fix exists. Not publishing leaves users exposed to a flaw that attackers may already know. The vendor is not engaging. The researcher has no leverage and considerable legal exposure.

Legal considerations. The discovery activity itself may have created exposure depending on how it was performed and where. Publication may attract legal threats. In some jurisdictions there are protections for good-faith security research; they vary and are not comprehensive. Contractual terms attached to the product may restrict reverse engineering and disclosure.

Decisions made.

1. Documented every contact attempt with dates, channels, and content.
2. Escalated to a national CERT, which has established channels to vendors and coordination experience.
3. The CERT made contact, established a vendor engineering contact, and brokered a timeline.
4. The researcher provided reproduction details to the vendor, offered to verify the fix, and agreed a disclosure date.
5. On the agreed date, a coordinated advisory published: the existence of the flaw, affected versions, the severity, the fix, and mitigations, without a working exploit.
6. Full technical detail was withheld until deployment data indicated substantial patch uptake.

Outcome. The flaw was fixed and an advisory issued jointly. The researcher's conduct was cited approvingly. The vendor subsequently published a disclosure policy and a security contact, which was arguably the more valuable outcome.

Lessons.

A coordinator solves the unresponsive vendor problem and is the correct answer far more often than publication is.

Escalation is not publication. Researchers frequently treat "publish" as the only lever when a vendor stalls; it is the last one.

Documentation of the contact attempts was what made the escalation credible.

Withholding exploit detail while retaining advisory detail is the standard balance and it satisfies defenders without arming attackers on day one.

Best practices. Look for a published policy and security contact first. Document every attempt. Escalate to a coordinator before considering publication. Agree a timeline in writing. Publish the advisory, not the exploit. Take advice before publishing anything.

3.8 Cross-Case Comparison

Case	The central dilemma	The decision that resolved it	Legal exposure avoided
Exposed backup	Confirm by downloading, or stop at existence	Stop at existence; report via a CERT	Unauthorized access; possession of health data
Journalism	Publish on documents of unknown provenance	Verify independently; publish what is supported	Defamation; source exposure; reliance on tainted material
Due diligence	Accept insider records that answer the question	Refuse in writing; notify counsel; reframe	Trade secret misappropriation; transaction contamination
Protest monitoring	Monitor lawful political activity for safety planning	Predicate requirement, pre-agreed threshold, documented purge	Constitutional and human rights exposure; political database
Academic research	Study public posts from a vulnerable community	Ethics review, no quotation, community engagement	Terms breach; participant identification and harm
Fraud investigation	"Everything on this person"	Written refusal; scoped alternative; ask the subject	Disproportionate processing; harassment; regulatory complaint
Vulnerability disclosure	Publish or stay silent with an unresponsive vendor	Escalate to a coordinator	Legal threats; user exposure

Two patterns run through all seven. **In six of seven, the resolving decision made the investigation less capable and more defensible**, which is the trade this chapter exists to teach. And **in every case**

the record of what was declined mattered as much as the record of what was done: the undownloaded file, the written refusal, the purged material, the absent quotations. Documentation of restraint is the artifact that survives scrutiny.

Part 4: Chapter Summary

Investigative capability is asymmetric, and that asymmetry is why the field has ethics. The investigator chooses the subject, assembles the picture, and usually acts without any gatekeeper reviewing each decision. The person bearing the risk of a mistake is generally not the investigator. Capability is not authorization, harm falls on the subject, and nobody is watching, which is why frameworks exist: judgment in the moment is unreliable without them.

Every decision raises two separate questions. The legal question asks whether something is permitted; the ethical question asks whether it is right. They have different sources, different enforcers, and different failure consequences, and four combinations exist. The largest and most dangerous quadrant is lawful and unethical, which is where most real decisions live. Rule 8 governs it: lawful is the floor, not the ceiling, and where law and ethics diverge, the stricter one governs your conduct. Where an ethical obligation appears to point at something unlawful, that is never an individual investigator's decision to make alone; stop, preserve, and escalate.

Privacy protects context, not secrecy. Reasonable expectation of privacy, contextual integrity, and the mosaic effect do the analytic work. Most of what privacy protects was shared deliberately in one setting and is violated by being moved to another. The aggregate you assemble from public parts is a new thing that the subject never made public, and you created it. Data categories matter: personal data is broader than PII, sensitive and special category data should be treated as off limits absent advice, and "anonymized" is a technical claim requiring justification rather than a label. The principles common to modern regimes translate directly into practice, and data minimization is the strongest single constraint on OSINT: necessity and proportionality stop most bad collection, and they are the steps investigators skip because "it might be relevant" feels like diligence. Privacy harms are concrete, including the chilling harm that falls on populations rather than individuals. Third parties appear only in a relevant capacity, incidental data is deleted on identification, and minors are categorical.

"It is public" answers a question about the source and not about your authority. Accessibility, authorization, lawfulness of use, and propriety are four different questions. Public is not binary: published, public by legal requirement, publicly accessible by default, practically obscure, available by error, and available through circumvention are six different states, and the last two are not public at all. Practical obscurity is a real protection and aggregation destroys it, which is a decision you are making about someone's ability to move on. Copyright, data protection, and contract all survive publication.

Consent is frequently not the relevant question, and manufacturing it is worse than not having it. Valid consent is freely given, specific, informed, unambiguous, capable, revocable, and documented. Explicit consent is required for interviews, recordings, research participation, and any testing of a system you do not own. Implied consent covers only what the context genuinely supports. Consent inferred by the collector from someone's public posting is not consent at all. Where consent does not

apply, identify and document the basis that does.

Copyright applies to public material. The fact-expression distinction is the investigator's most useful principle: report the facts, paraphrase the expression, quote briefly with attribution where wording matters. Internal evidence use is lower risk than republication. Fair use is an open-ended four-factor analysis in a few jurisdictions; fair dealing is a narrower closed list in others. Public domain status must be verified rather than assumed, and open licences are grants on terms, where non-commercial is broader than selling and no-derivatives catches cropping and annotation.

Data is a liability as well as an asset. Retention is driven by purpose, legal obligation, limitation periods, contract, and regulatory guidance, and it is overridden entirely by a litigation hold. Disposal on schedule is a professional act, not a failure of diligence. Deletion that leaves backups intact has deleted nothing, cloud synchronization creates copies you did not choose, and every disposal is recorded with what, when, by whom, by what method, under what authority, and how verified.

Jurisdiction arises on several bases at once and the regimes can conflict. Territory, effects, nationality, targeting, data location, data subject location, and contract each create a claim, and compliance with one regime is not a defence to another. The investigator's job is not to resolve cross-border questions but to recognize them, to map the implicated jurisdictions at planning, to narrow the footprint where possible, and to escalate conflicts.

Coordinated vulnerability disclosure is the professional standard. Stop at establishing existence, never access or retain third-party personal data, find and follow any published policy, report privately through the right channel, state your timeline up front, coordinate in good faith, and escalate to a coordinator rather than to publication when a vendor stalls. Finding and reporting carries real legal risk to the finder, which is reduced by going no further than necessary, documenting actions and non-actions, checking for safe harbor language, and taking advice before reporting anything significant and certainly before publishing.

Legal limitations span fourteen or more areas, of which computer misuse, data protection, defamation, harassment, trade secret, consumer reporting, contract, and licensing catch investigators most often. The recurring traps all share one shape: confusing accessibility, absence of damage, good intentions, or a client's instruction with authorization.

Professional ethics converge on a small set of commitments across every investigative field: honesty about identity, lawfulness, accuracy, proportionality, minimization, fairness to subjects, confidentiality, independence, accountability, and harm avoidance. Three frameworks structure hard decisions: the five-question test for routine calls, multi-lens analysis where consequences, duties, character, and fairness may disagree, and stakeholder mapping where many parties are affected and the ones who did not consent and cannot protect themselves get the most weight. The failure modes are capability creep, purpose drift, moral licensing, diffused responsibility, abstraction, certainty, normalized deviance, and selective rigour, and normalized deviance is the most dangerous because it is invisible from inside.

Refusal is a professional skill. State specifically what you will not do, give the reason in terms of law, standards, or scope, offer the lawful alternative, put it in writing, escalate if pressed, and be prepared to withdraw. Decide in advance what you will refuse, because the decision is far harder to make for the

first time under pressure.

And across all seven case studies, the decision that resolved the dilemma made the investigation less capable and more defensible, while the record of what was declined mattered as much as the record of what was done. The undownloaded file, the written refusal, the purged material, the absent quotations: documentation of restraint is the artifact that survives scrutiny.

Part 5: Key Terms

Grouped by theme. Terms carried from earlier chapters are marked and restated briefly.

5.1 Ethics and Law

Ethics. The standards a profession holds itself to, which are stricter than law by design.

Law. The minimum standard a society enforces, written broadly and lagging practice.

Rule 8. Lawful is the floor, not the ceiling; where law and ethics diverge, the stricter governs conduct.

Lawful but unethical. The quadrant containing most real investigative dilemmas: permitted conduct that a professional should not undertake.

Escalation. Referring a question to counsel, a supervisor, or an ethics body rather than deciding it alone.

Proportionality. The requirement that the intrusiveness of a method match the importance and necessity of the purpose.

Necessity. The requirement that collection be genuinely required for a stated purpose, not merely potentially useful.

Least intrusive means. The obligation to use the method that answers the question with the smallest privacy impact.

Ethical decision framework. A structured method for reasoning through a dilemma and producing a record of the reasoning.

Multi-lens analysis. Examining a dilemma through consequences, duties and rights, character, and fairness, and treating disagreement among the lenses as the substance of the dilemma.

Stakeholder map. A listing of affected parties with what each stands to gain or lose, whether they consented, and whether they can protect themselves.

Normalized deviance. Small departures from standards becoming routine because no harm has yet resulted.

Moral licensing. Treating a good purpose as authorization for questionable means.

Capability creep. Doing something because you discovered you could.

Purpose drift. Using data collected for one purpose for another, without a decision.

Selective rigour. Applying strict evidentiary standards to unwelcome evidence and loose ones to welcome evidence.

5.2 Privacy

Privacy. Protection of appropriate information flows and of a person's ability to control the context in which information about them is used.

Reasonable expectation of privacy. Whether a reasonable person would expect the observation, recording, or compilation in question.

Contextual integrity. The principle that information flows carry norms from their original context, and that moving information between contexts can violate privacy even where nothing was secret.

Mosaic effect (Ch.2). The creation of a sensitive whole from individually non-sensitive public parts.

Practical obscurity. Protection created by the difficulty of finding technically available information, which aggregation destroys.

Personal data. Any information relating to an identified or identifiable person.

Personally identifiable information (PII). A narrower concept: data identifying a specific individual directly or in combination.

Sensitive or special category data. Data whose misuse creates heightened risk, including health, biometric, genetic, racial or ethnic origin, religious or philosophical belief, political opinion, trade union membership, sexual orientation, and in some regimes criminal history.

Quasi-identifier. A field that does not identify alone but does in combination, such as postcode plus date of birth plus occupation.

Pseudonymization. Replacing identifiers while retaining the ability to re-identify with additional information; the data remains personal data.

Anonymization. Irreversible de-identification, which removes data from most regimes if the claim is genuinely justified.

Re-identification. Recovering identity from supposedly de-identified data, frequently easier than assumed.

Data minimization. Collecting only what is necessary for the stated purpose.

Purpose limitation. The principle that data collected for one purpose may not be freely repurposed.

Storage limitation. The principle that data is kept only as long as necessary.

Lawful basis. The legal ground for processing personal data, such as consent, contract, legal obligation, vital interests, public task, or legitimate interests.

Legitimate interests. A lawful basis requiring a documented balancing of the processor's interest against the individual's rights.

Data subject rights. Rights individuals hold over their data, commonly including access, rectification,

erasure, restriction, objection, and portability.

Chilling effect. The alteration of lawful behavior by people who believe they are observed.

Dignitary harm. The harm of being profiled or surveilled, independent of any further consequence.

5.3 Public Information and Consent

Publicly available information (Ch.2). Information any member of the public can lawfully obtain without defeating a control.

Availability by error. Material exposed by misconfiguration or mistake, which is not public and must not be collected.

Circumvention. Defeating any control, including weak ones; places material outside OSINT entirely.

Accessibility versus authorization. The distinction between being able to reach information and being permitted to collect it.

Consent. A person's agreement, given with sufficient knowledge and freedom to be meaningful.

Explicit consent. Clearly and specifically given, usually in writing, for a stated purpose.

Implied consent. Reasonably inferred from conduct in context, and limited to what the context supports.

Informed consent. Consent given with adequate understanding of what, by whom, for what, for how long, and with what consequences.

Inferred consent. A collector's assumption that consent exists; not consent.

Blanket consent. Broad agreement to unspecified future uses; weak and frequently ineffective for sensitive processing.

Freely given. Consent obtained without penalty for refusal and without bundling to unrelated benefits.

Revocability. The requirement that consent can be withdrawn as easily as it was given.

Capacity. The ability to consent, raising specific issues for minors and vulnerable adults.

Pretexting (Ch.4). Obtaining information by misrepresenting identity or purpose; outside OSINT and frequently unlawful.

5.4 Copyright

Copyright. Exclusive rights in original expression fixed in a tangible form.

Fact-expression distinction. The principle that facts are not protected but a particular expression of them is.

Fair use. An open-ended exception weighing purpose and character, nature of the work, amount and substantiality, and market effect.

Fair dealing. A closed-list exception permitting specified purposes such as research, criticism, review,

news reporting, and quotation.

Public domain. Material with no subsisting copyright, through expiry, ineligibility, or dedication.

Creative Commons. A family of licences granting permission on stated terms, not an abandonment of copyright.

BY, SA, NC, ND. Attribution, share-alike, non-commercial, and no-derivatives licence elements.

Moral rights. Rights of attribution and integrity persisting separately from economic rights in many jurisdictions.

Database right. Protection in some jurisdictions for substantial investment in compiling a database, separate from copyright in its contents.

Derivative work. An adaptation of a protected work; cropping and annotating can create one.

Attribution. Crediting the author, required under many licences and expected professionally regardless.

5.5 Retention and Disposal

Retention schedule. A document stating, per data class, how long material is kept and on what basis.

Retention driver. The reason a period is set: purpose, legal obligation, limitation period, contract, or regulatory guidance.

Limitation period. The period during which a legal claim may be brought, which can require retention.

Litigation hold. An obligation to preserve material when litigation is reasonably anticipated, which suspends the retention schedule entirely.

Secure disposal. Destruction of data such that it cannot be recovered, by overwrite, cryptographic erasure, device wipe, or physical destruction.

Cryptographic erasure. Rendering encrypted data unrecoverable by destroying the key.

Certificate of destruction. Documentation from a destruction provider recording what was destroyed and how.

Backup expiry. The scheduled deletion of backup copies, without which deletion is incomplete.

Disposal record. The record of what was disposed of, when, by whom, by what method, under what authority, and how it was verified.

Incidental third-party data. Data about people unrelated to the requirement, deleted on identification rather than at closure.

5.6 Jurisdiction

Jurisdiction. The authority of a legal system to regulate conduct or resolve a dispute.

Territorial jurisdiction. Authority based on conduct occurring within a territory.

Effects jurisdiction. Authority based on substantial effects within a territory from conduct outside it.

Nationality jurisdiction. Authority based on the actor's nationality or place of establishment.

Targeting. Deliberately directing activity at a territory, creating a jurisdictional hook.

Data subject location. A basis used by modern data protection regimes to reach processing wherever it occurs.

Extraterritorial application. A law reaching conduct outside the enacting jurisdiction.

Conflict of laws. The situation where two or more legal systems impose incompatible obligations.

Blocking statute. A law prohibiting compliance with certain foreign legal demands.

Mutual legal assistance treaty (MLAT). A formal government-to-government mechanism for obtaining evidence abroad, available to authorities rather than private parties.

Letters rogatory. Judicial requests for assistance from a foreign court.

Cross-border transfer rules. Restrictions on moving personal data to other jurisdictions.

Governing law and forum clause. Contractual terms specifying which law applies and where disputes are heard.

5.7 Disclosure and Legal Limitations

Responsible disclosure / coordinated vulnerability disclosure (CVD). Reporting a vulnerability privately to the party who can fix it, allowing a reasonable fix window, and coordinating any public disclosure.

Full disclosure. Immediate public release of vulnerability details.

Non-disclosure. Private reporting with no public release.

Disclosure timeline. The agreed period between report and publication, commonly measured in tens of days and adjustable by circumstance.

Safe harbor language. A commitment in a published disclosure policy not to pursue good-faith researchers acting within a stated scope.

security.txt. A conventional file at a known location on a website giving security contact details.

CERT / CSIRT. Computer emergency response or security incident response teams, which can act as disclosure coordinators.

Coordinator. A third party who brokers communication between a finder and a vendor.

Advisory. A published notice describing a vulnerability, affected versions, severity, fix, and mitigations, without a working exploit.

Unauthorized access. Accessing a system, account, or data without authorization or in excess of it.

Interception. Acquiring the contents of a communication you are not party to.

Defamation. Publication of a false statement causing reputational harm.

Trade secret misappropriation (Ch.3). Acquiring or using another party's protected information through improper means.

Consumer reporting rules. Regulation of information used for decisions about employment, credit, insurance, or housing.

Course of conduct. A pattern of acts which, taken together, can constitute harassment or stalking even where each act is lawful.

Private investigator licensing. A requirement in many jurisdictions to hold a licence to conduct investigative work for others.

Admissibility. Whether evidence may be used in a proceeding, which depends on how it was obtained and handled.

Part 6: Knowledge Assessment

6.1 Short Answer (20 questions)

Answer in three to five sentences unless otherwise noted.

1. Explain why investigative capability creates ethical obligations, using the concept of asymmetry.
2. Distinguish the legal question from the ethical question on at least four dimensions.
3. Describe the four combinations of legal and ethical, and explain which quadrant contains most real dilemmas and why.
4. State Rule 8 and explain what it means in practice.
5. Explain what an investigator should do when an ethical obligation appears to point toward something unlawful, and why.
6. Define contextual integrity and give an example of a privacy violation in which nothing secret was disclosed.
7. Explain the mosaic effect and why "each fact was public" is an inadequate defence.
8. Distinguish personal data, PII, and sensitive or special category data.
9. Explain why "anonymized" is a claim requiring justification rather than a label.
10. Name five principles common to modern data protection regimes and state what each means for an investigator.
11. Explain the sentence "it is public answers a question about the source, not about your

authority."

12. Describe the six degrees of public and identify which two are not public at all.
13. Explain practical obscurity and what an investigator is doing when they destroy it.
14. Distinguish explicit, implied, and inferred consent, and explain why the third is not consent.
15. Name four situations in which consent is the relevant question and two in which it is not.
16. Explain the fact-expression distinction and how an investigator applies it in a report.
17. Explain why data is a liability, and name three obligations that holding it creates.
18. Explain what a litigation hold does and why it matters to a retention schedule.
19. Name five bases on which jurisdiction can arise and explain why compliance with one regime is not a defence to another.
20. Describe the coordinated disclosure process and name four practices that reduce legal risk to the finder.

6.2 Multiple Choice (15 questions)

1. Rule 8 states that: a) Legal compliance is sufficient b) Lawful is the floor, not the ceiling, and the stricter of law and ethics governs conduct c) Ethics apply only where law is silent d) Legal advice is required for all collection
2. The quadrant containing most real investigative dilemmas is: a) Legal and ethical b) Legal and unethical c) Illegal and ethical d) Illegal and unethical
3. A person shares their address with a delivery company and it later appears in an investigative profile. The concept describing what has gone wrong is: a) Anonymization b) Contextual integrity c) Fair dealing d) Purpose limitation as applied to copyright
4. Which is the strongest single constraint on OSINT collection in most data protection regimes? a) Accuracy b) Data minimization c) Portability d) Transparency
5. Material exposed on a misconfigured public server is: a) Public, because it is accessible b) Public, if no password was required c) Not public; availability by error is not publication d) Public for research purposes only
6. A person posts a photograph on a public profile. This constitutes: a) Explicit consent to its use in an investigation b) Implied consent to aggregation and analysis c) Consent to people seeing a photograph, and nothing more d) Blanket consent under the platform's terms
7. An investigator wants to report a company's revenue figure taken from a news article. The correct approach is: a) Quote three paragraphs with attribution b) Report the fact and cite the source, paraphrasing any explanation c) Reproduce the article in an annex d) Avoid using the figure at all
8. Under a Creative Commons NC licence, use in a client-facing investigative report is: a) Clearly permitted, because no sale occurs b) Potentially prohibited, because commercial is broader than

selling c) Permitted with attribution d) Permitted if the report is internal

9. A litigation hold: a) Shortens the retention period b) Suspends the retention schedule entirely until counsel says otherwise c) Applies only to paper records d) Is optional in private investigations

10. Deleting the case files while leaving the nightly backups intact means: a) The data has been deleted b) The data has not been deleted; backup expiry must be addressed c) Deletion is complete after 30 days automatically d) Only personal data needs backup consideration

11. An investigator in country A researches a subject in country B on a platform established in country C, about individuals located in country D. The correct conclusion is: a) Only country A's law applies b) The platform's terms determine the applicable law entirely c) Several regimes may apply simultaneously and can conflict d) International law resolves the question

12. On discovering an unsecured database containing third-party personal data, the correct first action is: a) Download a sample to establish what is exposed b) Stop at establishing existence; do not access or retain the data c) Post the finding publicly to warn affected people d) Contact the affected individuals directly

13. Safe harbor language in a published disclosure policy: a) Guarantees immunity from all legal action b) Is a commitment not to pursue good-faith researchers acting within the policy's stated scope c) Applies to all vendors by default d) Removes the need to report privately

14. Which statement about a course of conduct is correct? a) If each individual act is lawful, the pattern is lawful b) A pattern of individually lawful acts directed at a person can engage harassment provisions c) Course of conduct applies only to physical surveillance d) Public sources cannot form a course of conduct

15. The ethical failure mode that is hardest to detect from inside an organization is: a) Capability creep b) Moral licensing c) Normalized deviance d) Abstraction

6.3 True or False (10 questions)

Mark true or false. For each false statement, write one sentence explaining what makes it false.

1. If an activity is legal, it is acceptable professional practice.
2. Privacy protects only information that is secret.
3. Publishing information about oneself removes others' obligations when processing it.
4. Consent is required for all lawful processing of personal data.
5. Facts stated in a copyrighted article are themselves copyrighted.
6. Public domain status can be assumed for all government publications.
7. Holding data indefinitely is the safest option for an investigator.
8. Compliance with the data protection law of your own country is a defence to another country's regime that also applies.

9. Escalating an unresponsive vendor to a national CERT is a form of public disclosure.
 10. Documenting what you declined to do is as professionally important as documenting what you did.
-

Part 7: Critical Thinking Exercises

Each group targets one skill. Produce the artifact the exercise names, and where a decision is required, record the reasoning in the form the chapter specifies.

Distinguishing legal from ethical issues

7.1 For each, state whether the primary issue is legal, ethical, or both, and explain: (a) an investigator creates a fake profile to view a restricted account; (b) an investigator compiles a full profile of a private individual entirely from public posts; (c) an investigator uses a client's login to check a supplier portal; (d) an investigator publishes a finding that names a junior employee whose role was incidental; (e) an investigator retains an evidence set for six years with no schedule.

7.2 A client instructs you to do something that is lawful and that you consider improper. Write the refusal following the six-step structure in Section 1.10.5, including the lawful alternative.

7.3 Identify a practice in any field you know that is legal, common, and in your view unethical. Analyse it using the multi-lens framework and state where the lenses disagree.

Evaluating privacy concerns

7.4 An investigation into a corporate fraud requires establishing where a company director was on three specific dates. Describe three methods ranging from least to most intrusive, state which you would use and why, and identify the point at which the method becomes disproportionate.

7.5 You hold, from public sources, a private individual's employer, gym schedule, vehicle, neighbourhood, and children's school. Analyse this using the mosaic effect, state what you have created, and describe your obligations regarding the material.

7.6 A dataset has had names and email addresses removed. It retains postcode, date of birth, job title, and employer. Assess whether it is anonymized, and describe what you would need to establish before treating it as non-personal data.

Determining whether consent is required

7.7 For each, state whether consent is required, and if not, what the applicable consideration is: (a) recording an interview with a witness; (b) reviewing a client's own customer records; (c) collecting public posts about a company; (d) testing a client's web application for vulnerabilities; (e) using a photograph of a person taken at a public event in a report; (f) surveying members of an online community for research.

7.8 A colleague argues that by agreeing to a platform's terms of service, users have consented to their

public posts being collected and analysed by anyone. Write a response addressing freely given, specific, informed, and the distinction between the platform's rights and yours.

7.9 You need to record a call with a client contact who is in a different jurisdiction from you. Describe the issue, what you would establish before recording, and what you would do if you could not establish it in time.

Identifying copyright considerations

7.10 Your report needs to convey what a competitor's product page claims. Describe three ways to do this ranging from highest to lowest copyright risk, and state which you would use.

7.11 You want to include a photograph from a news article showing a facility. Identify every legal issue engaged, and describe two alternatives that avoid them.

7.12 You have built a dataset by manually collecting 400 public listings. A colleague proposes publishing it as a research resource. Identify the copyright, database right, contract, and privacy issues, and state your recommendation.

Assessing jurisdictional challenges

7.13 Map the jurisdictions implicated by this scenario and identify the two most likely conflicts: your firm is in country A, your client in country B, the subject company in country C, its customers across the EU, the platform hosting relevant material in country D, and your cloud storage in country E.

7.14 A client asks you to collect information about individuals located in a jurisdiction whose data protection regime you believe applies to you. Describe what you would establish, who you would ask, and what you would do while waiting for the answer.

7.15 You discover that the most useful records for your investigation are available in a jurisdiction with a blocking statute that may prohibit their transfer to your client's country. Describe the issue and the three options you would present to the client.

Recommending responsible disclosure procedures

7.16 You discover credentials for a regional government service committed to a public code repository. Write your first-hour action plan, including what you will and will not do, whom you will notify, and in what order.

7.17 A vendor responds to your private report with a legal threat and demands you sign a non-disclosure agreement before they will discuss the issue. Describe your options, your recommendation, and the reasoning.

7.18 Draft the opening paragraph of a disclosure email to a vendor with no published security contact, covering identification, the finding at a high level, your intentions, and your proposed timeline, in a tone likely to produce engagement rather than defensiveness.

Applying ethical decision frameworks

7.19 Apply the five-question test to this decision: an investigator wants to attend a public meeting of a community group, without stating their purpose, to observe discussion relevant to their investigation. Record the answers and the decision.

7.20 Apply the multi-lens framework to this dilemma: you have found evidence that strongly suggests wrongdoing by a person who is not your subject, in an unrelated matter, discovered incidentally. Your engagement does not cover it. Record where the lenses disagree and what you would do.

7.21 Build a stakeholder map for a decision to publish an investigative finding that identifies a small business by name. Identify every affected party, what each stands to gain and lose, whether they consented, and whether they can protect themselves, and state how the map changes your recommendation.

Part 8: Hands-On Lab Exercises

General Lab Guidance

No collection is required in this chapter. Every lab uses provided fictional material, deliberately. A chapter about restraint should not send you out collecting.

Lab 1 is standalone. Labs 2 through 5 are chained on one fictional investigation. Keep every artifact.

Everything is fictional. Every organization, person, address, and finding is invented.

Rules 1 through 8 apply. Rule 8 in particular: several exercises describe conduct that is lawful and unacceptable, and identifying that gap is the point.

A reminder about what you are producing. These labs ask you to identify legal issues, not to resolve them. A submission that says "this raises a question under data protection law that requires advice, and here is precisely what I would ask" scores higher than one that confidently states what the law requires.

Rubric scale. 0 to 4 per criterion: 4 professional, 3 competent, 2 developing, 1 attempted, 0 missing or fundamentally incorrect.

Lab 1: Identifying Legal and Ethical Issues in Investigation Scenarios

Time required: 2 to 2.5 hours **Format:** Individual, then small group comparison **Difficulty:** Foundational to intermediate

Objectives

1. Identify the legal and ethical issues raised by a proposed investigative action.
2. Distinguish issues that require legal advice from those requiring professional judgment.

3. Recommend a compliant alternative that serves the underlying need.
4. Apply the decision flow from Section 1.1.4.

Prerequisites

- Sections 1.1 through 1.4 and 1.9, and comparison tables 2.1, 2.2, 2.4, and 2.10.

The Scenarios

All fictional.

Scenario A: The convenient login. An investigator is engaged by a company to examine a supplier relationship. The client's procurement manager offers their own login to the supplier's customer portal, saying "just use mine, it will save you weeks." The portal contains order histories and pricing that would answer the central question.

Scenario B: The complete profile. A client asks for "a full background workup" on an individual who is a sole trader supplying them. The investigator can lawfully assemble, from public sources, the person's home address, vehicle, family members' names, gym membership, church attendance, and their child's school.

Scenario C: The helpful ex-employee. During an investigation into a competitor's expansion, a former employee of that competitor contacts the investigator and offers to describe the competitor's internal expansion plans "off the record," saying they are no longer bound by anything.

Scenario D: The research shortcut. An investigator needs to monitor 40 marketplace listings daily for changes over six weeks. Manual checking would take two hours a day. A script would take ten minutes to write. The platform's terms prohibit automated access.

Scenario E: The forgotten dataset. An investigator closing a case discovers a folder containing an export of 12,000 customer records, provided by the client eighteen months ago for a different matter. It was never used, never logged, and never deleted. The client has since been acquired.

Scenario F: The public interest publication. A journalist has established, from public records, that a named local official's spouse owns a company that received council contracts. The spouse holds no public office and has made no public statements. The journalist plans to name both.

Steps

Step 1 (15 min). For each scenario, write the underlying need in one sentence: what does the investigator actually need to know or achieve? This is the sentence that makes a compliant alternative findable.

Step 2 (50 min). Complete Worksheet 1A for each scenario: every legal issue raised (with the category from Section 1.9.1), every ethical issue raised, which quadrant of the legal/ethical grid the proposed action falls in, and whether the issue requires legal advice or professional judgment.

Step 3 (25 min). Apply the decision flow from Section 1.1.4 to each scenario on Worksheet 1B, recording the answer at each of the seven steps and the point at which the flow terminates, where it

does.

Step 4 (30 min). Recommend a compliant approach for each on Worksheet 1C: what you would do instead, what it would and would not achieve compared with the proposed action, what it would cost in time or money, and what you would tell the client.

Step 5 (15 min). For the two scenarios you consider hardest, write the escalation: exactly what question you would put to counsel, phrased so that it can be answered. "Is this legal?" is not answerable; "does the platform's prohibition on automated access create exposure under [applicable computer misuse regime] where the material is otherwise publicly viewable, in [jurisdiction]?" is.

Step 6 (10 min). Self-check: in how many scenarios was the proposed action lawful? In how many was it acceptable? Note the difference.

Worksheet 1A: Issue Identification

Scenario	Legal issues (with category)	Ethical issues	Quadrant	Advice or judgment?
----------	------------------------------	----------------	----------	---------------------

Worksheet 1B: Decision Flow

Scenario	1 Lawful?	2 Authorized?	3 Necessary?	4 Proportionate?	5 Harm?	6 Comfortable?	Terminates at
----------	-----------	---------------	--------------	------------------	---------	----------------	---------------

Worksheet 1C: Compliant Alternatives

Scenario	Compliant approach	Achieves	Does not achieve	Cost	What I tell the client
----------	--------------------	----------	------------------	------	------------------------

Expected Outcomes

- **Scenario A** terminates at step 1 or 2. Using another person's credentials to access a third party's system is unauthorized access in most jurisdictions, and the client cannot authorize access to a system they do not control. The compliant alternative is to request the data from the supplier under the contract, or obtain it from the client's own records of the same transactions.
- **Scenario B** is the clearest lawful-and-unacceptable case in the set. Each element may be lawful to find; the aggregate is a targeting package on a private individual, and the child's school is categorically excluded. The compliant alternative is a scoped commercial due diligence: the trading entity, its registration, licensing, litigation, and financial standing.
- **Scenario C** requires distinguishing what the former employee may lawfully say from what they may not. Publicly known matters and their own general experience are one thing; their former employer's confidential expansion plans are another, and "no longer bound" is a legal

conclusion the investigator should not accept from the source. Decline the confidential material in writing, notify counsel, document the contact.

- **Scenario D** is the terms of service case, and the honest answer is that the two-hour manual cost is the cost of compliance. Acceptable alternatives include reducing the monitoring frequency, reducing the sample, checking whether the platform offers an authorized data access route, or seeking permission. Students who conclude "the terms are probably unenforceable so I will script it" have made the determination the chapter warns against.
- **Scenario E** engages retention, purpose limitation, and possibly breach notification. The data was collected for another purpose, has no basis for continued retention, and the client's acquisition complicates who may authorize disposal. The correct actions are to stop, not to browse it, notify counsel and the client, establish who has authority, and dispose of it verifiably with the disposal documented.
- **Scenario F** is the hardest and should produce disagreement. The official's contracting relationship is a legitimate public interest matter. The spouse is a private individual whose company's receipt of public contracts is a matter of public record. Strong answers distinguish naming the company (a matter of public record) from characterizing the spouse (which requires care), address right of reply, address defamation exposure, and recognize that the public interest test is doing the work rather than the public availability of the records.
- At least three scenarios should terminate before step 7. In four of six, the proposed action is lawful in at least some jurisdictions; in only one is it clearly acceptable.

Discussion Questions

1. In which scenarios did your group disagree, and was the disagreement about the law or about the ethics?
2. Scenario D costs two hours a day to do compliantly. How do you present that to a client who is paying?
3. Scenario B is composed entirely of lawful acts. Explain to a non-specialist why the total is different from the parts.
4. Which of your escalation questions would a lawyer actually be able to answer, and which would come back as "it depends"?
5. Which scenario would you be most likely to get wrong under deadline pressure?

Grading Rubric: Lab 1 (52 points)

Criterion	Weight	4 points looks like
Underlying need identified per scenario	x2	One clear sentence each; enables the alternative
Legal issue identification	x3	Correct categories; multiple issues per scenario where present

Criterion	Weight	4 points looks like
Ethical issue identification	x3	Distinct from the legal issues, not a restatement
Quadrant classification	x2	Correct, with the lawful-and-unacceptable cases identified
Advice versus judgment	x2	Correctly separated; escalation reserved for legal questions
Decision flow applied	x2	All seven steps per scenario; termination points correct
Compliant alternatives	x4	Genuine, achievable, and honest about what is lost
Client communication	x2	Professional, specific, offers the alternative
Escalation questions	x3	Answerable, jurisdiction-specific, precisely scoped
Scenario F nuance	x3	Public interest test applied; spouse and company distinguished; right of reply addressed

Total possible: 104 weighted. Passing: 71.

The Chained Case: The Alderway Housing Trust Investigation

Fictional in all respects.

The client. Alderway Housing Trust is a not-for-profit social housing provider managing 3,100 homes. It is engaging you through its general counsel.

The trigger. Two matters.

Matter 1: the maintenance contractor. Alderway's board has received an anonymous letter alleging that its principal maintenance contractor, **Kestrel Facilities Group**, has been billing for work not performed. Kestrel is registered in another country and operates through a local subsidiary.

Matter 2: the exposure. A tenant contacted Alderway to say that a spreadsheet containing tenant names, addresses, tenancy start dates, rent arrears status, and free-text maintenance notes for approximately 900 households appeared on a public file-sharing site. Some free-text notes describe access requirements relating to residents' health conditions.

Your engagement authorizes open source and public records investigation, examination of Alderway's own records provided to you, and interviews with Alderway staff arranged through counsel. It does not authorize contact with Kestrel, contact with tenants, examination of staff personal accounts, or any

access to non-public systems.

The decision. The board must decide within five weeks whether to terminate the contract, commission a formal audit, refer to authorities, or continue with corrective action, and separately what to do about the exposure.

Lab 2: Classifying Information

Time required: 2 to 2.5 hours **Format:** Individual **Difficulty:** Foundational to intermediate

Objectives

1. Classify information as public, private, sensitive, or protected, and justify each classification.
2. Determine appropriate handling for each class.
3. Recognize how classification changes with aggregation and context.

Prerequisites

- Sections 1.2 and 1.3, and comparison tables 2.2 and 2.3.

The Classification Set

Thirty items that arise in the Alderway investigation. All fictional.

#	Item
1	Kestrel Facilities Group's entry in the local corporate registry
2	The foreign parent company's filed annual accounts, obtained from its home registry
3	The names and roles of Kestrel's directors, from registry filings
4	A Kestrel director's home address, from a registry filing that lists it
5	Alderway's published board minutes recording the contract award
6	Alderway's internal procurement evaluation scores, provided to you by counsel
7	The anonymous letter to the board
8	The identity of the anonymous letter's author, if it could be determined
9	Kestrel's marketing photographs of completed work, from its website
10	A Kestrel employee's public professional profile

#	Item
	listing their role and tenure
11	The same employee's public posts about their weekend activities
12	Alderway's tenancy agreement template, published on its website
13	The exposed spreadsheet's file listing page on the file-sharing site
14	The exposed spreadsheet itself
15	Tenant names and addresses within the exposed spreadsheet
16	Rent arrears status within the exposed spreadsheet
17	Free-text maintenance notes describing residents' health-related access requirements
18	The count of affected households (approximately 900)
19	Alderway's own copy of the report from which the spreadsheet appears to derive
20	The 61 maintenance complaints Alderway has received in the period
21	The names of the complaining tenants
22	Aggregate complaint statistics by property block, with no names
23	Satellite imagery of properties where work was allegedly not performed
24	Building permit records for those properties
25	A local news article about social housing maintenance standards
26	Court records of a prior dispute involving Kestrel's parent
27	A photograph of a property interior, provided by a tenant to Alderway with a complaint
28	Alderway staff email discussing the contract, provided by counsel
29	A Kestrel invoice, provided by Alderway
30	Your own working timeline of the investigation

Steps

Step 1 (50 min). Classify every item on Worksheet 2A: class (public, private, sensitive, protected, or work product), whether it constitutes personal data, whether it is special category or sector-protected, and a one-line justification for the classification. Note that some items belong to more than one class and that the justification is what is graded.

Step 2 (30 min). Handling determination on Worksheet 2B. For each item: may it be collected, under what basis or authority, who may access it, how it is stored, how long it is retained, how it is disposed of, and whether it may appear in the report and in what form.

Step 3 (20 min). Aggregation analysis on Worksheet 2C. Identify at least four combinations of items in this set whose aggregate is more sensitive than any component, and state what the aggregate creates.

Step 4 (20 min). Reclassification on Worksheet 2D. Identify at least three items whose classification changes with context or purpose, and state the trigger for the change. Item 4 and item 22 are good candidates.

Step 5 (15 min). Exclusion list. Identify every item you would exclude from the investigation entirely, and state why. There should be at least three.

Worksheet 2A: Classification

#	Class	Personal data?	Special category or sector-protected?	Justification
---	-------	----------------	---------------------------------------	---------------

Worksheet 2B: Handling

#	Collect?	Basis / authority	Access	Storage	Retention	Disposal	May appear in the report?
---	----------	-------------------	--------	---------	-----------	----------	---------------------------

Worksheet 2C: Aggregation

Combination	What the aggregate creates	Mitigation
-------------	----------------------------	------------

Worksheet 2D: Reclassification

#	Original class	New class	Trigger
---	----------------	-----------	---------

Expected Outcomes

- **Item 14 is the hardest and most important.** The exposed spreadsheet is simultaneously public (accessible), protected (personal data of 900 households), and partly sensitive (item 17). The correct handling is that it should not be downloaded or retained in full; its existence, location,

approximate volume, and field structure should be established and recorded, and its content should never be reproduced. Students who classify it simply as public because it is accessible have made the chapter's central error.

- **Item 17 is special category data by implication.** Health-related access requirements are health data. It is off limits, and its existence is reported by category and count, never by content.
- **Item 4** is a genuine grey area and should be argued: the director's home address appears in a public filing, so it is public in the accessibility sense, and it is personal data, and its relevance to the investigation is likely nil. Strong answers exclude it as unnecessary rather than debating whether it is public.
- **Item 8** should be excluded categorically. The identity of an anonymous complainant is not within the investigation's purpose, and pursuing it would be improper regardless of feasibility.
- **Item 11** should be excluded. A Kestrel employee's weekend posts are personal, irrelevant, and outside any legitimate purpose. Item 10, their professional role, is within scope.
- **Item 21** should be minimized: complaint substance is needed, complainant identities are not, and the correct handling is de-identification at processing (Chapter 6).
- **Item 9** raises copyright rather than privacy, and may raise a further question if the photographs depict work Kestrel did not perform.
- **Item 27** is personal data, was provided for a complaint purpose, and may show a residence interior; it requires purpose-limitation analysis and should not be reproduced.
- **Item 30** is work product, not evidence, and should not appear in the evidence inventory.
- **Aggregation combinations** should include: 15 plus 16 plus 17 (a targeting and vulnerability package), 15 plus 20 plus 21 (identifying which named tenants complained), 22 plus 24 plus 23 (fine-grained property-level inference), and 3 plus 26 plus 2 (a legitimate corporate picture, included to show that aggregation is not always a problem).

Discussion Questions

1. Item 14 is accessible to anyone. Explain in two sentences why that does not resolve how you should handle it.
2. Which item did you find hardest to classify, and what made it hard?
3. Three items should be excluded entirely. Would excluding them weaken the investigation? If so, is that acceptable?
4. Aggregation made four combinations more sensitive than their parts. Which of the four would be most harmful if your case file leaked?
5. Item 22 is de-identified aggregate data. Under what circumstances would it stop being de-identified?

Grading Rubric: Lab 2 (56 points)

Criterion	Weight	4 points looks like
Classification accuracy	x3	Correct across most of the thirty, multiple classes where applicable
Justifications	x3	Reasoned, not labels
Item 14 handling	x4	Not downloaded or retained; existence and structure only; never reproduced
Item 17 identified as special category	x3	Recognized and excluded from content-level handling
Personal data identification	x2	Correct across the set, including indirect identifiers
Handling determinations	x3	Basis, access, storage, retention, disposal, and report treatment per item
Aggregation analysis	x3	Four-plus combinations with what each creates
Reclassification triggers	x2	Three-plus, with the trigger stated
Exclusion list	x3	Three-plus, including items 8 and 11, with reasons

Total possible: 104 weighted. Passing: 71.

Lab 3: Evaluating Evidence and Revising the Plan

Time required: 2.5 to 3 hours **Format:** Individual **Difficulty:** Intermediate to advanced

Objectives

1. Evaluate collected evidence for privacy, copyright, consent, and jurisdictional concerns.
2. Identify which items must be excluded, minimized, or handled differently.
3. Revise an investigation plan to address the identified risks.
4. Document the reasoning for each change.

Prerequisites

- All of Part 1, and comparison tables 2.2 through 2.6 and 2.10.
- Lab 2 complete.

The Draft Plan Extract

A previous investigator drafted the following. It contains problems.

Scope. This investigation covers all matters relating to Kestrel Facilities Group and its dealings with Alderway Housing Trust, and the circumstances of the data exposure.

Objectives. (1) Establish that Kestrel billed for work not performed. (2) Identify the individual responsible for the data exposure. (3) Assess the extent of the exposure by obtaining and analysing the exposed file. (4) Determine whether any Alderway staff member was involved.

Method. Open source research, public records, analysis of the exposed spreadsheet, review of Alderway records, and social media research on Kestrel personnel and Alderway maintenance staff. Automated monitoring of the file-sharing site will be established to detect re-uploads.

Evidence handling. All collected material will be stored on the investigator's laptop and a cloud drive, retained for the duration of the engagement and thereafter as a matter of record.

Reporting. The report will include representative extracts from the exposed file to demonstrate the nature of the data, photographs from Kestrel's website showing the disputed work, and the complaint details of affected tenants.

The Evidence Packet

Eighteen items already collected by the previous investigator. All fictional.

ID	Item	Notes
P1	Corporate registry record, Kestrel's local subsidiary	Downloaded official copy
P2	Foreign parent's annual accounts	Obtained from the home jurisdiction's registry portal
P3	Screenshot of the file-sharing page	Full page, URL and timestamp visible
P4	The exposed spreadsheet, downloaded in full	900 rows, includes health-related free text
P5	Twelve photographs copied from Kestrel's website	Saved as image files
P6	Alderway's procurement evaluation scores	Provided by counsel
P7	Social media posts by three named Kestrel employees	Includes personal and family content
P8	A social media post by an Alderway maintenance	Collected "to establish their movements"

ID	Item	Notes
	supervisor about a weekend event	
P9	Building permit records for eleven properties	Public records
P10	Satellite imagery of the same properties	Purchased commercial imagery
P11	Court records: a dispute involving the foreign parent	Obtained from a foreign court portal
P12	61 tenant complaints, with names and addresses	Provided by Alderway
P13	An audio recording of an interview with an Alderway staff member	No record of consent to record
P14	A local news article, saved in full	Copyrighted
P15	A list of file-sharing site accounts that downloaded the file	Obtained by the previous investigator from an unclear source
P16	Alderway staff email threads	Provided by counsel
P17	An export of Kestrel's public job postings	Manually collected
P18	A copy of the anonymous letter	Provided by Alderway

Steps

Step 1 (45 min). Evaluate every packet item on Worksheet 3A across four concerns: privacy, copyright, consent, and jurisdiction. For each concern present, state the specific issue and its severity. Some items raise several.

Step 2 (25 min). Disposition on Worksheet 3B. For each item: retain as is, retain with restrictions, minimize or redact, quarantine pending advice, or delete. State the reason and the action required.

Step 3 (30 min). Plan critique on Worksheet 3C. Identify every defect in the draft plan extract, by section, with the principle it violates and the consequence. There are at least twelve.

Step 4 (40 min). Revise the plan. Produce a corrected version of all five sections: scope, objectives, method, evidence handling, and reporting. Every objective must be measurable and completable by a negative finding (Chapter 6), and the method must survive the four tests.

Step 5 (20 min). Change log on Worksheet 3D. For each change: what changed, why, what capability is lost, and what mitigates the loss.

Step 6 (15 min). Escalation memorandum. Half a page to counsel: which items require legal advice before anything further is done, what precisely you are asking, and what you have done in the meantime.

Worksheet 3A: Evidence Evaluation

ID	Privacy concern	Copyright concern	Consent concern	Jurisdiction concern	Severity
----	-----------------	-------------------	-----------------	----------------------	----------

Worksheet 3B: Disposition

ID	Disposition	Reason	Action required	By when
----	-------------	--------	-----------------	---------

Worksheet 3C: Plan Critique

Section	Defect	Principle violated	Consequence
---------	--------	--------------------	-------------

Worksheet 3D: Change Log

Change	Reason	Capability lost	Mitigation
--------	--------	-----------------	------------

Expected Outcomes

- **P4 is the central problem.** The exposed spreadsheet was downloaded in full, placing 900 households' personal data, including health-related content, in the investigator's possession with no basis. Disposition: quarantine immediately, do not analyse, notify counsel, establish whether any lawful basis exists for retaining any part, and dispose of it verifiably if not. The extent of the exposure can be established from the file listing page, the field structure, and Alderway's own copy of the source report (item 19 in Lab 2), without holding the exposed data.
- **P15 is the second serious problem.** A list of accounts that downloaded the file could not have been obtained from public information; its source is unclear and probably improper. Quarantine, do not use, notify counsel, and document.
- **P13 has a consent defect.** An interview recording with no record of consent to record may be unlawful depending on jurisdiction and is improper regardless. Quarantine, establish what consent was given, and do not rely on it in the meantime.
- **P7 and P8 are disproportionate.** Personal and family content about employees, and a supervisor's weekend post collected to establish their movements, are outside any legitimate purpose in this engagement and P8 in particular is the beginning of a course of conduct directed at an individual. Delete both, document the deletion, and record that the collection should not have occurred.

- **P5 raises copyright**, and the report's proposal to reproduce the photographs raises it acutely. Description, or a small number of thumbnails with attribution if genuinely necessary, is the compliant approach.
- **P2 and P11 raise jurisdiction.** Obtaining foreign registry and court records is generally unobjectionable, and the transfer, storage, and use of any personal data within them may engage the foreign regime.
- **P12 requires minimization:** complaint substance is needed, complainant identities are not.
- **P14 must be paraphrased**, not reproduced.

The plan defects should include at least: the scope is unbounded ("all matters"); it has no exclusions; objective 1 is completable only by a positive finding; objective 2 pursues the identity of an individual, which the engagement does not authorize and which is disproportionate; objective 3 requires obtaining and analysing the exposed file, which is the problem; objective 4 targets Alderway staff, which the engagement excludes; the method authorizes social media research on named individuals with no proportionality limit; automated monitoring breaches likely terms and is prohibited by Rule 5; storage on a laptop and an unspecified cloud drive has no access control and creates a cross-border transfer question; retention "thereafter as a matter of record" is not a retention period; and the reporting section proposes reproducing exposed personal data, copyrighted photographs, and tenant complaint details, all three of which are wrong for different reasons.

- **The revised plan** should bound scope on all four dimensions with exclusions covering staff, tenants, the complainant's identity, family members, and minors; restate objectives as determinations rather than establishments; replace objective 2 with a scoped question about how the exposure occurred, referable to counsel if it points at an individual; replace objective 3 with establishing the exposure's extent without holding the data; specify manual collection only; specify controlled storage with a defined retention period; and specify that the report describes rather than reproduces.

Discussion Questions

1. P4 has already been downloaded. Explain why "we already have it, so we may as well use it" is wrong.
2. Objective 1 says "establish that Kestrel billed for work not performed." What does that phrasing do to an investigator, and what is the correct phrasing?
3. P8 was collected to establish a person's movements. Explain what that collection is, in the language of Section 1.9.
4. The revised plan is less capable. Name the single most significant capability lost and state whether the client is worse off.
5. Which item in the packet would you have been most tempted to keep, and what stopped you?

Grading Rubric: Lab 3 (72 points)

Criterion	Weight	4 points looks like
Four-concern evaluation across the packet	x3	Every item assessed; multiple concerns identified where present
P4 disposition	x4	Quarantine, no analysis, counsel, verifiable disposal, alternative route to the extent question
P15 disposition	x3	Recognized as improperly sourced; quarantined and escalated
P13 consent defect	x3	Identified; jurisdictional variation noted; quarantined
P7 and P8 disposition	x3	Deleted, documented, and characterized correctly
Copyright items handled	x2	P5 and P14 addressed with compliant alternatives
Jurisdictional issues identified	x2	P2 and P11 flagged appropriately
Plan critique completeness	x4	Twelve-plus defects with principles and consequences
Revised scope	x3	Four dimensions bounded; exclusions covering all required subjects
Revised objectives	x3	Measurable, negative-path completable, within the engagement
Revised method, handling, and reporting	x3	Manual collection, controlled storage, defined retention, description not reproduction
Change log	x2	Honest about capability lost, with mitigations
Escalation memorandum	x3	Specific, answerable questions; interim actions stated

Total possible: 144 weighted. Passing: 99.

Lab 4: Data Retention and Evidence Management Plan

Time required: 2 to 2.5 hours **Format:** Individual **Difficulty:** Intermediate

Objectives

1. Build a data classification and retention schedule for an investigation.
2. Specify storage, access control, and transfer arrangements appropriate to each class.
3. Specify secure disposal procedures with verification.
4. Address litigation hold, backups, and third-party copies.

Prerequisites

- Section 1.6, comparison table 2.9, and Chapter 6 Sections 1.5 and 1.7.
- Labs 2 and 3 complete. Bring the classification set and the revised plan.

Steps

Step 1 (25 min). Data classification schedule on Worksheet 4A. Define the classes you will use for this investigation, minimum five, with a definition and examples drawn from the Lab 2 set. Suggested classes: case administration, evidence (non-personal), evidence (personal data), evidence (special category), work product, and client-provided material. Justify any class you add or omit.

Step 2 (35 min). Retention schedule on Worksheet 4B. For each class: the retention driver, the period, the trigger that starts the clock, the disposal method, who authorizes disposal, and how disposal is verified. At least two classes must have a retention period measured in days rather than years, and you must state the reasoning.

Step 3 (25 min). Storage and access on Worksheet 4C. For each class: where it is stored, whether it is encrypted, who may access it, how access is logged, how it is backed up, and where the backups live. Address the cross-border question raised by cloud storage, and state what you would need to know before using a given provider.

Step 4 (20 min). Transfer and production on Worksheet 4D. How material moves to counsel, to the client, and to any third party: method, hashing, logging, and what is permitted to leave your control at all. Specify what must never be transferred.

Step 5 (20 min). Special provisions on Worksheet 4E. Write the specific arrangements for: the exposed spreadsheet if any part of it is retained; the health-related free text; tenant complainant identities; the anonymous letter; interview recordings; and incidental third-party data encountered during collection.

Step 6 (15 min). Litigation hold and exceptions. Write the litigation hold procedure: what triggers it, who declares it, what it suspends, how it is communicated, and how its release is recorded. Then write the exception procedure for a disposal that cannot be verified.

Step 7 (15 min). Closure disposal plan. A step-by-step procedure for closure: what is disposed of, in what order, by what method, with what verification, and what documentation is produced. Include working copies, backups, and third-party held copies.

Worksheet 4A: Classification Schedule

Class	Definition	Examples from the case	Sensitivity
-------	------------	------------------------	-------------

Worksheet 4B: Retention Schedule

Class	Retention driver	Period	Clock starts on	Disposal method	Authorized by	Verification
-------	------------------	--------	-----------------	-----------------	---------------	--------------

Worksheet 4C: Storage and Access

Class	Storage location	Encrypted?	Access	Access logging	Backup	Backup location and expiry
-------	------------------	------------	--------	----------------	--------	----------------------------

Worksheet 4D: Transfer and Production

Recipient	What may be transferred	Method	Hashing	Logging	What must never be transferred
-----------	-------------------------	--------	---------	---------	--------------------------------

Worksheet 4E: Special Provisions

Material	Provision
----------	-----------

Expected Outcomes

- Five-plus classes with real distinctions. A schedule that treats all evidence identically has not done the work.
- **The special category class must have the shortest retention and the tightest access**, and the honest answer for the health-related free text is that it should not be retained at all beyond a description of its existence.
- **At least two classes with retention measured in days**. Incidental third-party data is deleted on identification; any retained portion of the exposed data is retained for the shortest period that serves a defined purpose and no longer.
- **The backup problem must be addressed**. A schedule that deletes case files and leaves nightly backups for 90 days has a 90-day retention period regardless of what the schedule says.
- **The cross-border question must be recognized**. Cloud storage may place personal data in another jurisdiction, which is a transfer question, and the correct output is a statement of what you would need to establish about a provider before using it, not a confident answer.

- **The litigation hold procedure must suspend the schedule entirely** and must be triggered by reasonable anticipation of litigation rather than by the commencement of proceedings.
- **Transfer provisions must include a "never transferred" list**, which should include the exposed personal data, the health-related content, complainant identities, and any incidental third-party material.
- **The closure procedure must address working copies and third-party copies**, which are the two things students forget, and must produce a disposal record for each item.

Discussion Questions

1. Which class was hardest to assign a retention period to, and what made it hard?
2. Your schedule deletes something the client might later want. How do you present that decision to them in advance?
3. Explain to a non-specialist why keeping data "just in case" is a risk rather than a precaution.
4. A litigation hold arrives two days before your scheduled disposal. Describe exactly what happens.
5. What in your plan would fail if you were asked to prove, in a year, that a particular file had been destroyed?

Grading Rubric: Lab 4 (60 points)

Criterion	Weight	4 points looks like
Classification schedule	x3	Five-plus classes with real distinctions and case examples
Retention drivers	x3	Correct driver per class, not preference
Short retention where appropriate	x3	Two-plus classes in days, with reasoning
Special category handling	x4	Shortest retention, tightest access, health content not retained
Storage and access controls	x3	Per class, with encryption and access logging
Backup problem addressed	x3	Backup expiry aligned to the schedule
Cross-border storage question	x3	Recognized; states what must be established rather than asserting an answer
Transfer provisions	x2	Method, hashing, logging, and a never-transferred list

Criterion	Weight	4 points looks like
Special provisions	x3	All six materials addressed specifically
Litigation hold procedure	x3	Trigger, declaration, suspension, communication, release
Closure disposal procedure	x3	Ordered, verified, documented, covering working and third-party copies

Total possible: 132 weighted. Passing: 90.

Lab 5: Responsible Disclosure

Time required: 2.5 to 3 hours **Format:** Individual **Difficulty:** Advanced

Objectives

1. Analyse a vulnerability discovery and determine the appropriate response.
2. Identify the legal and ethical considerations bearing on disclosure.
3. Produce a coordinated disclosure plan with a timeline and escalation path.
4. Draft a professional disclosure communication.

Prerequisites

- Sections 1.8 and 1.9, and comparison table 2.7.
- Labs 2 through 4 complete.

The Discovery

Fictional.

While establishing how the Alderway spreadsheet came to be public, you examine the file-sharing site's public interface. You observe the following, without logging in, without creating an account, and without accessing anything not displayed to an anonymous visitor:

#	Observation
D1	The site assigns each uploaded file a URL containing a short sequential-looking identifier
D2	Changing the identifier in the address bar by one displays a different file's public landing page, belonging to an unrelated uploader
D3	The landing page displays the file name, size,

#	Observation
	upload date, and a download button, without authentication
D4	Files that the site's interface describes as "private, link only" appear to be reachable by the same identifier pattern
D5	The Alderway spreadsheet's landing page is marked "private, link only"
D6	You did not download any file other than establishing the behaviour on the Alderway file, which you had already retrieved (Lab 3, item P4)
D7	The site is operated by a company registered in a third country. Its website has a general "contact us" form and no security contact
D8	The site has no published disclosure policy and no security.txt
D9	The site's terms of service prohibit "automated or systematic access" and "attempting to access files not shared with you"
D10	You have not enumerated identifiers, have not scripted anything, and have made fewer than five manual requests in total

The implication. If the pattern holds, files that users believe are private may be enumerable by anyone, which would mean the Alderway exposure is not an isolated upload error but a systemic issue affecting an unknown number of users.

Steps

Step 1 (20 min). Analysis on Worksheet 5A. What have you established, what have you inferred, and what remains unknown? Distinguish the three rigorously, in the Chapter 5 sense. Then state, in one sentence each, the best case and worst case interpretations of the observations.

Step 2 (25 min). Legal and ethical assessment on Worksheet 5B. Identify every consideration bearing on your position: your own exposure from the observations already made, the terms of service position, the jurisdictional picture, your obligations to Alderway, your obligations to the site's other users, and the risk of publication. State which require legal advice.

Step 3 (20 min). Stop-or-continue decision. You could establish the systemic nature of the issue definitively by trying more identifiers. Write the decision and the reasoning, applying the five-question test and Section 1.8.5. Then state what you will do instead to characterize the issue.

Step 4 (30 min). Disclosure plan on Worksheet 5C: the recipient and how you identified them, the channel, the escalation path if there is no response, the timeline with its justification, what you will and

will not include in the report, what you will do about Alderway's own exposure in the meantime, and whether and when you would publish anything.

Step 5 (20 min). Stakeholder map on Worksheet 5D: the site operator, the site's other users, Alderway, Alderway's tenants, your client relationship, and yourself. What each stands to gain and lose, whether they consented, and whether they can protect themselves.

Step 6 (30 min). Draft the disclosure communication. A complete, professional message to the site operator. It must include: who you are, how you came to observe the behaviour, what you observed stated factually and without exaggeration, what you did not do, the potential impact, your proposed timeline, your offer to verify a fix, your contact details, and a clear statement of your intentions. Maximum one page. Tone matters and is graded.

Step 7 (20 min). Write the parallel advice to Alderway: what they should do now regarding their own exposure, independent of the site operator's response, including the notification question and the removal request.

Worksheet 5A: Analysis

Established	Inferred	Unknown
-------------	----------	---------

Worksheet 5B: Legal and Ethical Assessment

Consideration	Issue	Severity	Advice needed?
---------------	-------	----------	----------------

Worksheet 5C: Disclosure Plan

Element	Content
Recipient and how identified	
Channel	
Escalation path	
Timeline and justification	
Included in the report	
Excluded from the report	
Interim actions for Alderway	
Publication position	

Worksheet 5D: Stakeholder Map

Party	Stands to gain	Stands to lose	Consented?	Can protect themselves?
-------	----------------	----------------	------------	-------------------------

Expected Outcomes

- **The stop decision is the central test.** Trying further identifiers would establish the systemic issue and would also constitute attempting to access files not shared with you, contrary to D9, and possibly unauthorized access depending on jurisdiction. The correct decision is to stop, characterize the issue from what has already been observed, and state in the report and in the disclosure that the systemic nature is inferred rather than established, with the reason.
- **The analysis must distinguish rigorously.** Established: the URL pattern, that one adjacent identifier displayed an unrelated file, that the Alderway file is marked private and was publicly reachable. Inferred: that the pattern is systematic. Unknown: the scale, whether the site has controls not visible anonymously, and whether the behaviour is intentional design.
- **Own exposure must be assessed honestly.** Fewer than five manual requests, no enumeration, no scripting, and no downloads other than a file already retrieved is a defensible position and it is not zero risk, and legal advice before disclosing is the right call.
- **The recipient problem** should be solved by escalation to a coordinator: no security contact, no policy, a foreign operator, and a systemic issue affecting third parties is precisely the situation a national CERT exists for. A student who plans to use the general contact form as the only channel has missed it; a student who uses it and also engages a coordinator has it right.
- **The timeline must be stated in the first communication** and justified, and it should be responsive to the fact that other users' data may be exposed now.
- **Publication should be conditional and cautious:** no publication of the identifier pattern or any method that would enable enumeration, at any point, and any advisory limited to what users need in order to protect themselves.
- **Alderway's interim actions are independent of the site operator:** request removal, assess the notification obligation with counsel, notify the regulator if required, consider notifying affected households, and preserve their own evidence of the exposure.
- **The disclosure communication** is graded on tone as well as content. It should be factual, non-accusatory, specific about what was and was not done, clear about intentions, and easy for a non-security recipient to act on. It should not include exploitation detail, should not demand payment, and should not threaten publication.
- **The stakeholder map** should identify the site's other users as the party with the most to lose, who did not consent and cannot protect themselves, and should note that this is what makes prompt disclosure the obligation.

Discussion Questions

1. You stopped short of establishing the issue definitively. Explain to a technically minded client why that was the right call.
2. Your disclosure says the systemic nature is inferred, not established. Does that weaken the report? Does it weaken the disclosure?

3. The site operator is in a third country with no security contact. What would you do if the coordinator route also failed?
4. Alderway's interests and the site's other users' interests could diverge. Where, and whom do you serve?
5. Read your draft communication as if you were the recipient's general manager, who is not technical. Would you understand what to do? Would you feel accused?

Grading Rubric: Lab 5 (72 points)

Criterion	Weight	4 points looks like
Established, inferred, unknown separated	x4	Rigorous; the systemic claim correctly placed in "inferred"
Legal and ethical assessment	x3	Own exposure, terms, jurisdiction, and duties all identified
Stop decision and reasoning	x4	Stops; five-question test applied; alternative characterization stated
Recipient identification and coordinator use	x3	CERT or coordinator engaged; contact form not relied on alone
Timeline and justification	x3	Stated up front, justified by third-party exposure
Escalation path	x2	Defined for non-response and for a hostile response
Publication position	x3	No enabling detail at any point; advisory limited to protective information
Alderway interim advice	x3	Removal, notification assessment, regulator, evidence preservation
Stakeholder map	x3	All parties; other users correctly identified as most exposed
Disclosure communication: content	x4	All nine required elements present
Disclosure communication: tone	x3	Factual, non-accusatory, actionable by a non-specialist
Length discipline	x1	One page

Total possible: 144 weighted. Passing: 99.

Part 9: Capstone Assignment

The Fernbrook Community Health Network Investigation

Weight: 35% of chapter grade **Time required:** 6 to 9 hours **Format:** Individual **Deliverable:** An ethics and legal compliance report with supporting analyses, specified in Section 9.4

9.1 The Scenario

Everything below is fictional.

You have been engaged by the general counsel of **Fernbrook Community Health Network**, a not-for-profit operating twelve community clinics across two countries: eight in country A, where Fernbrook is headquartered, and four in country B, which is in a region with a comprehensive data protection regime.

The trigger. Four matters arrived within three weeks.

Matter 1: the billing vendor. Fernbrook's billing services vendor, **Halloway Revenue Partners**, is registered in country C. An internal reviewer has flagged that Halloway's invoices have risen 38% over two years while patient volume rose 6%. An anonymous message to Fernbrook's ethics line alleges that a Fernbrook manager receives payments from Halloway.

Matter 2: the exposed dataset. A security researcher contacted Fernbrook to report that a dataset appearing to contain appointment records, including patient initials, dates of birth, clinic locations, appointment types, and referring clinician names, for approximately 22,000 appointments, is downloadable from a public cloud storage location. The researcher says they downloaded a sample "to verify" and still has it.

Matter 3: the clinician's social media. A Fernbrook clinician has posted publicly about workplace conditions, naming the organization and describing patient volumes. Fernbrook's communications director wants "a full picture of what this person is saying and who they are talking to."

Matter 4: the research request. A university research group has asked Fernbrook for de-identified appointment data for a study on access to care. Fernbrook's board is inclined to agree and has asked whether it can.

The decisions. Fernbrook's general counsel must advise the board within six weeks on: what to do about Halloway; how to handle the exposure and the researcher; whether and how to respond to the clinician's posts; and whether to release data to the university.

Your engagement. You are engaged to advise on what may lawfully and ethically be investigated and how, and to conduct the open source and records elements of the investigation within those limits. You are not counsel and your report will be read by counsel. Your engagement authorizes open source and public records research, examination of Fernbrook records provided to you, and staff interviews arranged through counsel. It does not authorize contact with Halloway, contact with the researcher without counsel present, examination of staff personal accounts, access to any clinical system, or any

handling of patient data.

Complications.

- Health data is involved in Matters 2 and 4, and possibly Matter 3.
 - Two countries and a third for the vendor.
 - A statutory notification clock may already be running on Matter 2.
 - The researcher holds a sample of exposed patient data.
 - The clinician's posts may be protected speech, protected disclosure, or both.
 - Fernbrook's board wants the research request answered quickly.
-

9.2 Guidance on the Substance

Four matters, four different legal and ethical profiles. A weak submission produces one undifferentiated analysis. A strong one recognizes that Matter 1 is a records investigation with a jurisdictional wrinkle, Matter 2 is an incident with notification obligations and a third party holding data they should not, Matter 3 is a speech and employment matter where the intrusive investigation the client wants is the wrong answer, and Matter 4 is a data governance question about the meaning of de-identification.

Matter 3 is the test of whether you will tell a client no. The instruction as given is disproportionate, and part of your job is to say so and to offer what is legitimate.

You are not counsel. Every deliverable should distinguish clearly between what you assess, what you recommend, and what requires legal determination, and the questions you frame for counsel are graded on whether they are answerable.

9.3 What You Must Produce

Deliverable 1: Matter-by-Matter Legal and Ethical Analysis (24 points)

For each of the four matters, a structured analysis covering:

- The issues raised, categorized as privacy, public information, consent, copyright, retention, jurisdiction, disclosure, or other legal limitation.
- Which are legal questions requiring advice and which are professional judgment calls.
- The applicable considerations in general terms, with an explicit statement that jurisdictional determination is for counsel.
- The quadrant analysis: what is lawful, what is ethical, and where they diverge.
- The specific questions you would put to counsel, phrased answerably.

Deliverable 2: Collection Boundaries Determination (16 points)

A written determination, per matter, of what may lawfully and ethically be collected:

- What you will collect, with the basis and the purpose.
- What you will not collect, with the reason.
- The proportionality assessment for anything touching an identifiable individual, in writing.
- The individuals policy for this engagement, addressing staff, patients, the clinician, the anonymous reporter, the researcher, and any family members.
- **A categorical statement on patient data**, which your engagement excludes entirely, and how you will characterize the exposure without handling it.

Deliverable 3: Consent and Authorization Assessment (10 points)

- For each proposed activity, whether consent is the applicable question, and if not, what is.
- The authorization required for each activity, and from whom.
- The specific consent arrangements for staff interviews, including recording.
- An analysis of Matter 4: what consent or basis would be required for the research release, what de-identification would have to achieve, and why "de-identified" is a claim requiring justification.

Deliverable 4: Jurisdictional Analysis (12 points)

- A map of every jurisdiction implicated, with the basis on which each may apply.
- The specific points at which regimes may conflict.
- The effect of jurisdiction on: where you store material, which providers you may use, what you may transfer to the client, and what you may include in a report that may travel.
- What you would narrow to reduce the jurisdictional footprint.
- The questions for counsel.

Deliverable 5: Data Retention and Handling Plan (12 points)

- A classification and retention schedule covering every material class in this engagement.
- Storage, access control, encryption, and transfer arrangements, with the cross-border question addressed.
- Special provisions for anything relating to patients, the exposed dataset, the clinician, and the anonymous reporter.
- Litigation hold procedure and closure disposal procedure with verification.

Deliverable 6: Responsible Disclosure and Incident Strategy (14 points)

For Matter 2:

- The disclosure and notification picture: who must be told what, by whom, and the fact that timing may be statutory and is for counsel to determine.
- **The researcher problem:** they hold a sample of exposed patient data. Your recommended approach to that conversation, what you would ask for, what you would not do, and why counsel must be present.
- Whether the researcher should be treated as a good-faith reporter, and what would change that assessment.
- The evidence preservation requirements for the exposure itself.
- What Fernbrook should publish, if anything, and when.
- Your position on your own handling of the exposed data, which is that you will not handle it.

Deliverable 7: Ethics and Legal Compliance Report (18 points)

Maximum five pages plus annexes. Addressed to general counsel, written in the knowledge that it may be read by a regulator.

Required: a summary of the position on all four matters; for each, what may be investigated, how, and what may not; the ethical reasoning where it goes beyond the legal position, with Rule 8 applied explicitly; **the recommendation on Matter 3, which should decline the instruction as given and offer a legitimate alternative**; the questions referred to counsel, collected in one place; the residual risks and their mitigations; and a statement of professional limits, making clear what you are not advising on.

Deliverable 8: Ethical Decision Records (4 points)

For the three hardest decisions in this engagement, a completed decision record each: the decision, the framework applied, the analysis under each lens where the multi-lens framework is used, where the lenses disagreed, the decision taken, who was consulted, and what would change it.

Deliverable 9: Decision Justification Log (2 points)

Minimum eighteen rows across all matters. Absence caps the capstone at 70.

9.4 Capstone Grading Rubric (110 points, scored to 100)

Deliverable	Criterion	Points
1. Analysis	All four matters analysed separately with distinct profiles	6
	Issues correctly categorized	5

Deliverable	Criterion	Points
	Legal questions separated from judgment calls	5
	Quadrant analysis with divergences identified	4
	Counsel questions answerable and jurisdiction-specific	4
2. Boundaries	Collect and do-not-collect determinations per matter, with reasons	5
	Written proportionality assessments	4
	Individuals policy covering all six categories of person	4
	Categorical patient data exclusion, with the alternative characterization route	3
3. Consent	Consent applicability per activity, with the alternative basis where it does not apply	3
	Interview and recording arrangements	2
	Matter 4 de-identification analysis	5
4. Jurisdiction	Complete map with bases	4
	Conflict points identified	3
	Effect on storage, providers, transfer, and reporting	3
	Narrowing proposals and counsel questions	2
5. Retention	Classification and schedule covering all classes	4
	Storage, access, encryption, cross-border	3
	Special provisions for the four sensitive categories	3
	Hold and closure disposal with verification	2
6. Disclosure	Notification picture, correctly referred to counsel for timing	3

Deliverable	Criterion	Points
	Researcher approach, with counsel present and a defined ask	5
	Good-faith assessment and what would change it	2
	Preservation, publication position, and own-handling position	4
7. Report	Structure, length, and clarity for a legal reader	3
	All four matters covered with what may and may not be done	4
	Rule 8 applied explicitly where ethics exceeds law	3
	Matter 3 instruction declined with a legitimate alternative	5
	Counsel questions collected; residual risks; professional limits stated	3
8. Decision records	Three records, framework applied, disagreement surfaced	4
9. Decision log	Eighteen-plus rows	2
Total		110, scored to 100

Grade bands: 90 to 100 exemplary, 80 to 89 proficient, 70 to 79 competent, 60 to 69 developing, below 60 not yet passing.

Automatic deductions:

- Proposing to collect, download, handle, or analyse any patient data, or reproducing any patient identifier or clinical detail anywhere in any deliverable: **minus 30**. The engagement excludes it, the data is a special category, and the exposure can be characterized by field structure, volume, and date without touching content.
- Accepting the Matter 3 instruction as given, or proposing collection of the clinician's associations, contacts, or personal content: **minus 20**.
- Failing to identify that the researcher's retained sample is a live problem requiring counsel: minus 12.
- Stating what the law requires in a named jurisdiction as a conclusion rather than as a question for counsel: minus 8 per instance.

- Treating the four matters as one undifferentiated analysis: minus 10.
- Proposing to contact Halloway or the researcher without counsel, contrary to the engagement: minus 8 per instance.
- Asserting that any named individual acted improperly: minus 10 per instance.
- No cross-border storage analysis: minus 6.
- Missing decision justification log: capped at 70.

Guidance on the expected shape of a strong package. Matter 1 is the most conventional: records research on Halloway and its corporate structure, comparative analysis of the invoice trend against sector norms, and a scope that excludes the named manager's personal life while permitting examination of Fernbrook's own records concerning approvals. The anonymous allegation is testable against the approval record rather than against anyone's character, and the anonymous reporter's identity is out of scope categorically. Matter 2 is an incident: preservation, a notification assessment that is counsel's to make on timing, a carefully handled conversation with the researcher conducted with counsel and aimed at secure deletion with verification rather than at accusation, and an absolute position that you will not handle the data yourself. Matter 3 is the refusal: the instruction seeks a full picture of a person's speech and associations, which is disproportionate, potentially engages protected disclosure and employment law, and should be declined in writing with a legitimate alternative such as a factual record of what was posted publicly, limited to statements about the organization, assessed for accuracy, with no examination of the clinician's contacts, associations, or personal content. Matter 4 is governance: de-identification of appointment data with dates of birth, clinic locations, and referring clinicians is a strong claim that requires justification, re-identification risk assessment is the substance of the question, and the answer is very likely that a data sharing agreement, a formal de-identification standard, and an ethics review are prerequisites rather than optional extras.

Part 10: Answer Keys

Instructors may wish to remove this section from student copies. Legal points below are general and educational, not legal advice.

10.1 Short Answer Key

1. The investigator chooses the subject, assembles the picture, and usually acts with no gatekeeper, while the subject frequently never knows. The risk of error falls on the subject rather than the investigator. Capability is therefore not authorization, and because nobody is reviewing each decision, frameworks are required to substitute for the oversight that does not exist.
2. Any four of: the question asked (permitted versus right), the source (statute and contract versus professional standards and moral reasoning), the enforcer (courts and regulators versus professional bodies, employers, and self), the consequence (liability versus harm and lost trust), determinacy (often determinable with advice versus requiring judgment), and speed of change (years versus continuous).

3. Legal and ethical (proceed), legal and unethical, illegal and ethical (escalate, never decide alone), illegal and unethical (do not). Most real dilemmas sit in legal and unethical, because law is written broadly and lags practice, so the great majority of investigative conduct is legally unaddressed and must be governed by professional standards.
4. Rule 8: lawful is the floor, not the ceiling, and where law and ethics diverge, the stricter governs conduct. In practice every action passes two gates: fail the legal gate and stop and escalate; pass the legal gate but fail the ethical gate and do not do it.
5. Stop, preserve, and escalate to counsel and to the organization. These situations are real and rare, and they are not decisions for an individual investigator, because the individual bears neither the information nor the authority to weigh them, and acting alone converts a difficult situation into a personal liability.
6. Contextual integrity holds that information flows carry norms from the context in which they occurred. An example: a person's address given to a delivery company, appearing in an investigative profile. Nothing secret was disclosed and the flow violated the norms of the original context.
7. The mosaic effect is the creation of a sensitive whole from individually non-sensitive public parts. "Each fact was public" is inadequate because the subject never published the aggregate, could not have consented to it, and the aggregate enables harms that no component enables. The harm assessment attaches to what you created, not to what you collected.
8. Personal data is the broadest: any information relating to an identified or identifiable person. PII is narrower and largely US-derived: data identifying a specific individual directly or in combination. Sensitive or special category data is a subset whose misuse creates heightened risk, including health, biometric, genetic, racial or ethnic origin, religious belief, political opinion, union membership, and sexual orientation.
9. Because re-identification from small numbers of quasi-identifiers is frequently possible, so whether a dataset is genuinely irreversibly de-identified depends on the data, the population, and what else is available. Applying the label does not make it true, and the claim must be justified by an assessment of re-identification risk.
10. Any five of: lawfulness, fairness and transparency (a basis that survives being stated); purpose limitation (data for one purpose is not free for another); minimization (collect only what is necessary, the strongest constraint on OSINT); accuracy (unverified attributions are a compliance problem as well as an analytic one); storage limitation (retention schedules); integrity and confidentiality (custody and access control); accountability (documentation).
11. It means that establishing accessibility answers only the easiest of four questions. The others are whether you are authorized to collect given who you are, whether your intended use is lawful, and whether you should given the harm and the purpose. An investigator who has answered only accessibility has answered none of the hard questions.
12. Published for the public; public by legal requirement; publicly accessible by default; public but practically obscure; available due to error; available through circumvention. The last two are not

public: availability by error is not publication, and anything reachable only by defeating a control is outside OSINT entirely.

13. Practical obscurity is protection created by the difficulty of finding technically available information. An investigator who aggregates and surfaces it is removing that protection, which for an individual can mean the difference between a twenty-year-old record being effectively past and being instantly findable, and recognizing that you are the one removing it is part of the job.

14. Explicit consent is clearly and specifically given, usually in writing, for a stated purpose. Implied consent is reasonably inferred from conduct and covers only what the context supports. Inferred consent is the collector deciding on the subject's behalf that consent exists, which is not consent at all, because consent is something the subject gives rather than something the collector concludes.

15. Consent is the question for: recording an interview, research involving human subjects, testing a system you do not own, and obtaining a background check on a named individual for a stated purpose. It is not the question for: reviewing a client's own records, or researching a company's public filings, where authority and the absence of personal data respectively are what matters.

16. Facts are not protected by copyright; a particular expression of them is. An investigator reports the fact and cites the source, paraphrases explanation in their own words, and quotes briefly with attribution only where the exact wording matters.

17. Data you hold must be protected, may be compelled to be produced, and can be lost. Holding it creates a security obligation, legal exposure through discovery and access requests, a compliance obligation under storage limitation, harm potential if it leaks, and cost.

18. A litigation hold is an obligation to preserve material when litigation is reasonably anticipated, and it suspends the retention schedule entirely until released. It matters because routine disposal of material relevant to anticipated litigation, after the obligation attaches, is a serious problem, so the schedule must state the trigger, who declares it, and how release is recorded.

19. Any five of: territorial, effects, nationality or establishment, targeting, data location, data subject location, and contractual choice of law. Compliance with one regime is not a defence to another because each system's claim to regulate is independent, and two regimes can impose incompatible obligations simultaneously.

20. Discovery with minimum access; assessment; identification of the recipient; checking for a published policy; private report with a stated timeline; coordination; escalation to a coordinator if necessary; and coordinated public disclosure if any. Risk-reducing practices: go no further than necessary, never access or retain third-party personal data, do not test systems you do not own without written authorization, check for safe harbor language, document actions and non-actions, report through a coordinator where appropriate, and take advice.

10.2 Multiple Choice Key

#	Answer	Note
1	b	The stricter of law and ethics

#	Answer	Note
		governs
2	b	Legal and unethical
3	b	Contextual integrity
4	b	Data minimization
5	c	Availability by error is not publication
6	c	Consent to being seen, nothing more
7	b	Report the fact, paraphrase the expression
8	b	Commercial is broader than selling
9	b	Suspends the schedule entirely
10	b	Backup expiry must be addressed
11	c	Several regimes may apply and can conflict
12	b	Stop at existence
13	b	A commitment within the policy's stated scope
14	b	A course of individually lawful acts can engage harassment provisions
15	c	Normalized deviance

10.3 True or False Key

#	Answer	If false, why
1	False	Lawful is the floor; a great deal of lawful conduct is professionally unacceptable
2	False	Privacy protects appropriate information flows and context, most of which involve nothing secret
3	False	Publication by a person does not remove others' obligations when processing their personal data

#	Answer	If false, why
4	False	Consent is one of several bases; most investigative processing relies on others
5	False	Facts are not protected; the article's expression of them is
6	False	Whether government works are in the public domain varies by jurisdiction
7	False	Data is a liability: retention creates security, discovery, compliance, and harm exposure
8	False	Each regime's claim is independent; compliance with one is not a defence to another
9	False	Escalation to a coordinator is private; publication is a separate and later step
10	True	

10.4 Critical Thinking Guidance

7.1 (a) Both: unauthorized access and misrepresentation of identity, and an ethical breach of the honesty commitment. (b) Primarily ethical: lawful in many places, disproportionate, and creating a targeting package through aggregation; possibly legal too where harassment or data protection provisions apply. (c) Legal: unauthorized access to a third party's system, which the client cannot authorize. (d) Both: defamation and privacy exposure, and an ethical failure of proportionality toward someone whose role was incidental. (e) Legal: storage limitation, plus an ethical failure of minimization.

7.2 The refusal should name the specific action, give the reason in terms of standards or scope rather than personal preference, offer a lawful alternative that serves the underlying need, be in writing, state the escalation path, and avoid accusation.

7.3 Graded on the quality of the multi-lens analysis and on honesty about where the lenses disagree, not on the practice chosen.

7.4 Least to most intrusive: public records and published schedules; the company's own records held by the client; commercially available travel or transaction data about the individual. The third is disproportionate for most fraud investigations of ordinary scale and should be excluded. The point of disproportion is typically where the method reaches beyond the person's role and into their life.

7.5 You have created a targeting package enabling location, schedule prediction, and access to a minor. The aggregate is not public. Obligations: do not extend it, do not share or publish it, delete unless a

documented lawful purpose and authorized process exist, escalate rather than retain personally, and record what you did.

7.6 Not anonymized. Postcode, date of birth, job title, and employer are quasi-identifiers that in combination will uniquely identify many individuals. Before treating it as non-personal data you would need a documented re-identification risk assessment against the actual population, generalization or suppression of the quasi-identifiers, and a justification you would be willing to defend.

7.7 (a) Yes, and in some jurisdictions all-party consent is required. (b) No; the client's authority and their own basis for holding the records. (c) Not for the company; for identifiable individuals appearing, the questions are necessity, proportionality, and basis. (d) Yes, explicit and written, with scope defined. (e) Not consent; copyright in the photograph, and privacy or publicity rights in the subject depending on jurisdiction and use. (f) Yes, formally, plus ethics committee approval.

7.8 The response should note that terms of service govern the relationship between the user and the platform, not between the user and you; that consent must be freely given, specific, and informed, which a blanket clause is not; that the platform's rights under its terms are not transferable to third parties by inference; and that in any event the applicable question for the investigator is the lawful basis and proportionality, not the user's consent.

7.9 Recording consent requirements vary by jurisdiction, and some require all parties to consent. Establish which jurisdiction's rules apply to the call, the position of both participants, and any organizational policy. If you cannot establish it in time, do not record; take contemporaneous notes instead and confirm the substance in writing afterward.

7.10 Highest to lowest risk: reproducing the page verbatim in the report; quoting substantial passages; describing the claims in your own words with a citation and a captured copy retained internally as evidence. Use the third.

7.11 Copyright in the photograph, potential privacy or publicity rights if identifiable people appear, terms of service on the source site, and moral rights in some jurisdictions. Alternatives: commission or purchase licensed imagery, or use publicly available satellite or street-level imagery from a source whose licence permits the use, or describe the facility.

7.12 Copyright in the individual listings' text and images; database rights in some jurisdictions in your compilation and possibly in the source; contract, because the platform's terms may restrict reuse and republication; and privacy, because seller information may be personal data. Recommendation: do not publish the dataset; publish aggregate findings and the methodology.

7.13 The map should list all six jurisdictions with the basis for each: your establishment in A, the client relationship in B, the subject's establishment in C, data subject location across the EU, the platform's establishment and terms in D, and data location in E. The two most likely conflicts are the EU data subject regime reaching processing conducted in A and stored in E, and any conflict between D's platform terms and the transfer rules applying to EU data subjects' personal data.

7.14 Establish where the individuals are located, what processing is proposed, what basis would apply, and whether your organization has any establishment or targeting connection. Ask counsel with

experience in that regime. While waiting, do not collect the personal data in question; proceed with the parts of the investigation that do not involve it, and record the pause and its reason.

7.15 The issue is a genuine conflict of laws in which compliance with one obligation may breach another. The three options: proceed only with the parts not implicating the blocking statute; seek the records through a channel the statute permits, which may involve authorities and be slow; or advise the client that the question cannot be answered from that jurisdiction within the engagement, and cover the gap contractually.

7.16 Do: stop, record exactly what was observed and when, do not use the credentials, do not test whether they work, do not access anything, capture only the page showing their presence, and notify your own management and counsel. Then identify the affected organization's security contact, report privately, and consider a coordinator given the public sector context. Do not: use, share, or publish the credentials at any point.

7.17 Options: sign and lose the ability to disclose; decline and continue coordinating without an agreement; escalate to a coordinator who can broker without an agreement binding you; withdraw. Recommendation is normally to decline a broad agreement, offer to continue coordinating on the merits, engage a coordinator, and take legal advice before responding, because signing an open-ended agreement under threat forecloses options and rewards a hostile response.

7.18 The paragraph should identify the sender, state briefly and factually what was observed and how it was encountered, state clearly what was not done, indicate the potential impact without exaggeration, propose a timeline, offer to verify a fix, and give contact details. It should not accuse, should not demand, and should not include exploitation detail.

7.19 The five answers should be recorded honestly. The decision turns on step 6 in most analyses: attending a public meeting is lawful and probably authorized, and observing without stating your purpose in a community setting is the point where most people become uncomfortable, particularly where the group is small enough that participants would reasonably assume everyone present is a participant.

7.20 The lenses will typically disagree: consequences may favour reporting, duties point to the limits of your engagement and to obligations to the person, character asks what a professional does with information they were not engaged to find, and fairness asks whether it is right that this person is caught by an investigation aimed elsewhere. The usual resolution is to record the observation without pursuing it, escalate to counsel and to your client's counsel, and let the decision about referral be made by parties with the authority to make it.

7.21 The map should identify the business owner, employees, customers, the client, the public, and the investigator. Employees are typically the party that did not consent, cannot protect themselves, and stand to lose most, and recognizing this frequently changes the recommendation toward naming the entity only where necessary, delaying publication until after right of reply, and considering whether the public interest is served by naming at all.

Appendix A: Reusable Templates

A.1 The Five-Question Test

PROPOSED ACTION: _____

1. Is it lawful, where I am, where the subject is, and where the data is? Y / N / UNSURE
2. Am I authorized: engagement, employer, terms? Y / N / UNSURE
3. Is it necessary for a stated, legitimate purpose? Y / N
4. Is it proportionate, and the least intrusive method that answers the question? Y / N
5. Who could be harmed, how badly, if I am wrong, if it leaks, or if it is misused? _____
6. Would I be comfortable if the subject, my employer, a regulator, and a journalist saw exactly what I did and why? Y / N

ANY "N" OR "UNSURE" ON 1 OR 2 → STOP AND ESCALATE
ANY "N" ON 3, 4, OR 6 → DO NOT PROCEED

DECISION: _____ RECORDED BY: _____ DATE: _____

A.2 Multi-Lens Decision Record

Element	Content
The decision to be made	
Consequences lens: outcomes for all affected	
Duties and rights lens: obligations regardless of outcome	
Character lens: what a professional of integrity does	
Fairness lens: is the burden justly distributed	
Where the lenses disagree	
Decision taken	
Consulted	
What would change this decision	
Recorded by, date	

A.3 Stakeholder Map

Party	Stands to gain	Stands to lose	Consented?	Can protect themselves?	Weight

A.4 Privacy Analysis Record

Step	Answer
Is a person identifiable, directly or in combination?	
Category: personal, sensitive, sector-protected	
Purpose, stated specifically	
Necessity: would the investigation fail without it?	
Proportionality: least intrusive method and narrowest scope	
Harm if wrong, if leaked, or if misused	
Safeguards: access, minimization, pseudonymization, retention	
Decision and basis	

A.5 Information Classification

Item	Class (public / private / sensitive / protected / work product)	Personal data?	Special category?	Collect?	Basis	Access	Retention	May appear in the report?

A.6 Retention Schedule

Class	Driver	Period	Clock starts	Disposal method	Authorized by	Verification	Backup expiry

A.7 Disposal Record

ITEM / CLASS: _____ ITEM IDs: _____
AUTHORIZED BY: _____ DATE AUTHORIZED: _____
METHOD: _____
PERFORMED BY: _____ DATE / TIME: _____
BACKUPS ADDRESSED: Y / N DETAIL: _____
THIRD-PARTY COPIES ADDRESSED: Y / N DETAIL: _____
VERIFICATION METHOD AND RESULT: _____
CERTIFICATE / EVIDENCE OF DESTRUCTION: _____

A.8 Jurisdictional Assessment

Question	Answer	Regime that may apply
Where am I when I collect?		
Where is the subject located or established?		
Where are the data subjects located?		
Where is the platform established, and what do its terms say?		
Where is the data stored and processed, including my storage?		
Where is my client, and where will the product be used?		
Where would any proceeding be brought?		

Conflicts identified: _____ **Escalated to counsel:** Y / N **Narrowing applied:** _____

A.9 Disclosure Communication Skeleton

SUBJECT: Security issue affecting [product / service] - private report from [name / organization]

1. WHO I AM and why I am writing
2. HOW I ENCOUNTERED the issue, factually
3. WHAT I OBSERVED, specifically and without exaggeration
4. WHAT I DID NOT DO (no enumeration, no download, no testing beyond what is stated, no access to third-party data)
5. POTENTIAL IMPACT, described for a non-specialist
6. WHAT I AM ASKING: acknowledgement by [date], a point of contact, and an indication of remediation plans
7. MY PROPOSED TIMELINE and what I intend to do at each stage
8. MY OFFER to verify a fix and to coordinate any advisory
9. CONTACT DETAILS and preferred secure channel

Not included: exploitation detail · any third-party data · any demand for payment · any threat

A.10 Refusal Record

REQUEST RECEIVED: _____
FROM: _____ DATE: _____
WHAT I DECLINED, SPECIFICALLY: _____
BASIS (law / professional standard / engagement scope): _____
LAWFUL ALTERNATIVE OFFERED: _____
COMMUNICATED IN WRITING: Y / N DATE: _____
ESCALATED TO: _____

Appendix B: The Ethics and Legal Checklist

Run before collection begins, at each review point, and before any product leaves your hands.

Authority and authorization

1. Authority for the investigation is recorded.
2. My engagement covers everything I plan to do.
3. Anything requiring separate authorization has it, in writing.
4. Terms of service positions are recorded per platform.
5. Licensing requirements in my jurisdiction are confirmed.

Privacy 6. Every collection touching an identifiable person has a recorded purpose. 7. Necessity and proportionality are assessed in writing. 8. The least intrusive adequate method is being used. 9. Special category data is not being collected. 10. Third parties appear only in a relevant capacity. 11. No minors, anywhere. 12. Aggregation has been assessed for the mosaic effect. 13. Incidental third-party data is deleted on identification.

Public information 14. Everything collected was lawfully accessible without circumvention. 15. Nothing exposed by error has been collected. 16. No identity was misrepresented. 17. Practical obscurity considerations have been weighed.

Consent 18. Consent obtained where it is the applicable question, specific and documented. 19. Where consent does not apply, the applicable basis is recorded. 20. No consent has been inferred on a subject's behalf. 21. Recording consent obtained for every recorded interview.

Copyright 22. Facts reported, expression paraphrased. 23. Quotations brief and attributed. 24. Nothing substantial republished without advice. 25. Licence terms checked for any openly licensed material used.

Retention 26. A retention schedule exists with a driver per class. 27. Storage is access-controlled and encrypted where appropriate. 28. Backup expiry aligns with the schedule. 29. Litigation hold procedure exists and no hold is in force. 30. Disposal is verified and recorded.

Jurisdiction 31. Implicated jurisdictions are mapped. 32. Conflicts are identified and escalated. 33. Storage location and providers assessed for transfer implications.

Disclosure 34. Any vulnerability finding stopped at establishing existence. 35. No third-party personal data accessed or retained. 36. Published policy located and followed, or a coordinator engaged. 37. Timeline stated in the first communication.

Ethics 38. Every decision passed the five-question test, recorded. 39. Anything declined is recorded, with the reason. 40. Nothing in this file would embarrass me if the subject, a regulator, and a journalist

read it in full.

Appendix C: Where to Go Next

Skills to build after this chapter, in priority order:

1. **Find and read your own jurisdiction's data protection guidance.** Most regulators publish plain-language material for practitioners. An afternoon with it is worth more than any general chapter.
2. **Read one professional code in your intended field** in full: competitive intelligence, journalism, security research, licensed investigation, or research ethics. Note where it is stricter than the law.
3. **Learn your licensing position** before you take investigative work for anyone else.
4. **Practise writing refusals.** Draft five, for five different improper requests, each offering a lawful alternative. It is the single skill most likely to protect you.
5. **Practise framing questions for counsel.** Take five situations and write the question you would actually ask. Answerable questions get answers; "is this legal?" does not.
6. **Read a published coordinated disclosure policy and a published advisory**, and note what each includes and omits.
7. **Study a real enforcement action or professional sanction** in your field, and identify at which step of the decision flow it went wrong.

Habits to start now:

- Ask the ethical question separately from the legal one, every time.
 - Record the decision, including the decisions not to do something.
 - When you are certain, slow down; certainty is when the framework matters most.
 - Decide in advance what you will refuse, and write it down while nobody is pressing you.
 - Treat the subject as someone who will read your file one day.
-

End of Chapter 7